

Анонимизатор ПДн — юридический анализ и карта рисков

ЮРИДИЧЕСКИЙ_АНАЛИЗ.md

Дата анализа: 16 августа 2026 г. **Предмет:** сервис обезличивания/псевдонимизации текста в документах (docx, xlsx, pdf, rtf, odt, doc) с обратной операцией деанонимизации. **Адресат:** собственник продукта. Отдельный фокус — потенциальная сделка с ИНК (Иркутская нефтяная компания).

⚠ Документ отражает состояние на утро 16.08.2026. В течение того же дня часть выявленных проблем устранена, а часть фактов уточнена (в том числе: web/vercel.json удалён; платформа Vercel фактически не использовалась; получены документы ООО «ИНТЕРФОНИКА»; установлено, что правообладатель — физическое лицо без регистрации). **Актуальный статус и все расхождения с текстом ниже — в файле ЮРИДИЧЕСКИЕ_ДОКУМЕНТЫ/00_СТАТУС_выполнения.md.**

Условные обозначения по всему документу: [ЗАКОН] — прямое требование нормативного акта. [ПРАКТИКА] — сложившаяся практика регулятора / судов, не следующая буквально из текста нормы. [ИБ-ЗАКАЗЧИК] — не требование закона, а типовое требование службы ИБ корпоративного заказчика. [РЕКОМЕНДАЦИЯ] — моя оценка, а не норма. [СПОРНО] — норма допускает два толкования; даю оба и указываю консервативное. [ПРОВЕРИТЬ] — реквизит/сумма взяты из вторичного источника и требуют сверки с первоисточником до использования в переговорах.

0. Расхождения между исходным брифом и фактическим состоянием репозитория

Это первый и важный результат: **часть допущений, на которых строился запрос, репозиторием не подтверждается.** Юридические выводы ниже опираются на фактическое состояние кода, а не на бриф.

Утверждение в брифе	Что в коде на самом деле	Юридическое значение
Основной LLM — «qwen3.5-35b»	Дефолты противоречивы: server.py, llm.py, review.py → qwen3.5:9b; anonymize_document.py, worker.py, test_contract.py, eval_benchmark.py → gemma4:12b; usage_log.py тарифицирует по «Selectel Gemma 4 31B»; profile_run.py — google/gemma-4-12b-qat	Критично. От версии модели зависит весь блок B.14. Gemma 4 — Apache-2.0, Gemma 1–3 и производные — Gemma Terms of Use с цепочкой обязательств. Нужно зафиксировать, что <i>фактически</i> отдаёт шлюз
Natasha и OPF из сборки удалены	Natasha не удалена. engine.py:499 — ner_backend: str = "natasha" (значение по умолчанию), ner.py импортирует natasha, detectors.py:1071 использует natasha.MorphVocab как fallback морфологии. OPF (OpenAI Privacy Filter) в коде не найден	Лицензионные обязательства Natasha и её транзитивных зависимостей (pymorphy2 → словари OpenCorpora) сохраняются
Хостинг: был Vercel fra1, переносится в РФ	web/vercel.json в репозитории по-прежнему содержит "regions": ["fra1"]	Конфигурация ЕС-региона не удалена из кодовой базы. Для аудита это выглядит как действующая, а не «бывшая» схема

Утверждение в брифе	Что в коде на самом деле	Юридическое значение
Шлюз — oui.interfonica.cloud	Помимо него в коде: app.py:86 → https://jh.interfonica.cloud/user/ts-.../proxy/8000 (JupyterHub-прокси), loadtest.py → https://anon.cpcore.ru (публичный сайт)	Три разных внешних контура , а не один. Каждый — самостоятельный вопрос о том, где физически данные и кто оператор площадки
Маппинг только в памяти	Верно, но: _JOBS (server.py:91) хранит весь результат задания, включая mapping и исходные подстроки . TTL 600 с (_JOB_TTL_SECONDS). Плюс маппинг отдаётся клиенту в теле ответа	РАМ-хранение не устраняет статус ИСПДн, но влияет на модель угроз (см. п. 4)
Логи — logs/usage.jsonl	Верно. Записывается в т.ч. filename (usage_log.py:431) и error = str(exc) , куда через http_pool может попасть до 200 байт тела ответа шлюза	Имя файла — часто ПДн («Приказ_об_увольнении_Иванова_И.И.docx»). Это превращает лог в ИСПДн (см. п. 5)
Лицензия репозитория Apache-2.0	Файлов LICENSE и NOTICE в корне репозитория нет (найлены только внутри web/node_modules/)	Обязательства Apache-2.0 §4(a)/4(d) и CC BY-SA по словарям формально не исполнены
Bearer-токен защищает бэкэнд	Токен исходящий (к LLM и GLiNER). Во входящем контуре Python-сервера проверки авторизации нет; server.py:362 отдаёт Access-Control-Allow-Origin: *	Самостоятельный ИБ-риск, который заметит служба ИБ ИНК (см. п. 13)

1. Резюме для собственника

Прямо и без смягчения: в текущей конфигурации продукт нельзя продавать корпоративному заказчику, и как минимум два элемента схемы образуют состав административного правонарушения.

Первое. Сырой текст документа со всеми персональными данными уходит на внешний LLM-шлюз oui.interfonica.cloud **до** маскирования. Это передача ПДн третьему лицу. Она законна только как поручение обработки по ч. 3 ст. 6 152-ФЗ — то есть при наличии письменного договора поручения с оператором шлюза, с перечнем ПДн, перечнем операций, обязанностью конфиденциальности и обязанностью уведомлять о фактах неправомерной передачи. Такого договора у вас, по моей информации, нет. Без него передача — обработка без правового основания.

Второе. Фронтенд работал (и в коде по-прежнему сконфигурирован) в регионе Vercel **fra1, Франкфурт, ЕС**. Если через него проходили реальные документы граждан РФ, то состоялась трансграничная передача без уведомления Роскомнадзора по ч. 3 ст. 12 152-ФЗ, а консервативно — и нарушение локализации по ч. 5 ст. 18. Санкция за локализацию по ч. 8 ст. 13.11 КоАП — **до 6 млн Р для юрлица**, за повтор — до 18 млн. Удаление конфигурации сейчас нарушение не «отменяет», но останавливает его длящийся характер и сокращает риск.

Третье. Слово «обезличивание» вы использовать не вправе. Ст. 3 п. 9 152-ФЗ определяет обезличивание как действия, в результате которых **невозможно** определить принадлежность ПДн субъекту без дополнительной информации. Ваш сервис по замыслу обратим и хранит

таблицу соответствий — это псевдонимизация. Выход сервиса — по-прежнему персональные данные. С 1 сентября 2025 г. действует приказ РКН № 140 от 19.06.2025 (приказ № 996 от 2013 г. отменён), который прямо запрещает совместное хранение обезличенных и исходных данных и требует вести учёт операций.

Что при этом хорошо: сама архитектура законной быть может. Проблема не в идее, а в отсутствии бумаг. Шлюз, судя по тарификации в `usage_log.py`, работает поверх Selectel — российской площадки; если это подтвердится, трансграничной передачи на инференсе нет, и вопрос сводится к договору поручения и субпоручения. Лицензионный блок тоже почти чист: Gemma 4 отдана Google под Apache-2.0, GLiNER от knowledgator — Apache-2.0. Единственная реальная лицензионная заноза — словари OpenCorpora под CC BY-SA, приезжающие через rumorphy/Natasha.

Первые пять действий, по порядку. (1) Установить и задокументировать, что физически стоит за `oui.interfonica.cloud`: юрилицо, площадка, регион, логирование промптов. (2) Подписать договор поручения обработки с оператором шлюза. (3) Удалить `regions: fra1` и любые следы ЕС-контура, зафиксировать актом дату и факт переноса. (4) Подать уведомление в РКН по ст. 22. (5) Перестать писать «обезличивание» в маркетинге — заменить на «маскирование/псевдонимизацию ПДн».

Срок до состояния «можно показывать ИНК»: 3–4 недели на документы, 6–10 недель на архитектурные изменения, без которых договор подписывать нельзя.

2. Матрица рисков

Вероятность оценена как «реализуется при первой же проверке / первом же вендорском аудите» (высокая), «реализуется при инциденте или жалобе» (средняя), «требуется совпадения обстоятельств» (низкая).

№	Риск	Норма (реквизиты)	Вер.	Санкция / последствие	Что делать	Срок
R1	Передача сырых ПДн на внешний шлюз без договора поручения	ч. 3, ч. 5 ст. 6 ФЗ от 27.07.2006 № 152-ФЗ	Высокая	ч. 1 ст. 13.11 КоАП: 150–300 тыс. Р юрилицу [ПРОВЕРИТЬ]; при утечке — ч. 12–14: 3–15 млн Р; отказ ИНК от сделки	Договор поручения + субпоручение; запрет логирования промптов у шлюза	0–14 дн.
R2	Обработка ПДн на Vercel fra1 (ЕС) — нарушение локализации	ч. 5 ст. 18 152-ФЗ; ч. 8 ст. 13.11 КоАП	Средняя	1–6 млн Р юрилицу; повтор (ч. 9) — 6–18 млн Р [ПРОВЕРИТЬ]	Удалить <code>vercel.json</code> , акт о переносе и уничтожении, фиксация периода	0–7 дн.
R3	Трансграничная передача без уведомления РКН (период Vercel)	ч. 3 ст. 12 152-ФЗ (ред. ФЗ от 26.07.2026 № 265-ФЗ)	Средняя	Предписание РКН, запрет/ограничение передачи; сопутствующие составы 13.11	Служебная записка с оценкой периода и объёма; решение — подавать ли ретроспективно	0–14 дн.
R4	Отсутствие уведомления об обработке ПДн в РКН	ст. 22 152-ФЗ; ч. 10 ст. 13.11 КоАП	Высокая	100–300 тыс. Р юрилицу [ПРОВЕРИТЬ]	Подать уведомление, указав трансграничную передачу, если она есть	0–14 дн.

№	Риск	Норма (реквизиты)	Вер.	Санкция / последствие	Что делать	Срок
R5	Заявление «обезличивание» в маркетинге и договоре	п. 9 ст. 3, ст. 3 п. 9 152-ФЗ; приказ РКН от 19.06.2025 № 140	Высокая	Недостоверное заверение (ст. 431.2 ГК) → убытки, расторжение; репутационный удар в ИБ-аудите	Заменить термин, ввести оговорку в ofertу и договор	0–7 дн.
R6	logs/usage.jsonl содержит filename (часто ПДн) и текст ошибок	ст. 5 ч. 5, ст. 18.1, ст. 19 152-ФЗ	Высокая	Неучтённая ИСПДн; расхождение с перечнем ПДн → вопрос на аудите	Хешировать имя файла, санитизировать error, ввести срок хранения	0–14 дн.
R7	Отсутствие Политики обработки ПДн и назначенного ответственного	ч. 2 ст. 18.1, ст. 22.1 152-ФЗ; ч. 3 ст. 13.11 КоАП	Высокая	30–60 тыс. Р [ПРОВЕРИТЬ] + блокирующий пункт вендорского опросника	Разработать и опубликовать пакет	0–21 дн.
R8	Нет модели угроз и акта определения уровня защищённости	ст. 19 152-ФЗ; ПП РФ от 01.11.2012 № 1119; приказ ФСТЭК от 18.02.2013 № 21	Высокая	Предписание; провал ИБ-аудита ИНК	Разработать МУ по методике ФСТЭК 2021 г., акт УЗ	14–45 дн.
R9	Входной контур Python-сервера без аутентификации, CORS *	[ИБ-ЗАКАЗЧИК]; косвенно ст. 19 152-ФЗ	Высокая	Несанкционированный доступ → утечка → ч. 12–14 ст. 13.11 (3–15 млн Р)	Ввести аутентификацию, убрать *, mTLS/IP-allowlist	0–21 дн.
R10	Маппинг и результат в _JOBS (RAM) с TTL 600 с; отдаётся клиенту	ст. 19 152-ФЗ; п. 3, 6 приказа РКН № 140	Средняя	Дамп памяти / краш-дамп = утечка; довод «мы не храним» юридически слаб	Не хранить вовсе (stateless), шифровать в памяти, отключить core dumps	14–45 дн.
R11	Отсутствие NOTICE / LICENSE, CC BY-SA-словари OpenCorpora	Apache-2.0 §4(a),(d); CC BY-SA 4.0	Средняя	Претензия правообладателя; блокирующий пункт Open Source-опросника ИНК	Добавить LICENSE, NOTICE, THIRD_PARTY_LICENSES.md	0–21 дн.
R12	Неопределённость версии Gemma → возможные обязательства Gemma ToU	Gemma Terms of Use (ред. 01.04.2026); Gemma 4 — Apache-2.0	Средняя	Необходимость транслировать Prohibited Use Policy в ofertу	Зафиксировать модель у шлюза письменно; при Gemma ≤3 — добавить пункт в ofertу	0–14 дн.

№	Риск	Норма (реквизиты)	Вер.	Санкция / последствие	Что делать	Срок
R13	ИНК — вероятный субъект КИИ; SaaS у значимого объекта	ФЗ от 26.07.2017 № 187-ФЗ; ПП РФ от 08.02.2018 № 127 (ред. 07.11.2025)	Средняя	Отказ от внешнего SaaS; требование on-prem	Готовить on-prem/изолированную поставку как основной сценарий для ИНК	30–90 дн.
R14	Отсутствие режима коммерческой тайны у себя	ФЗ от 29.07.2004 № 98-ФЗ, ст. 10, 11	Высокая	Невозможность взыскать убытки; ИНК не примет NDA без встречного режима	Ввести режим КТ приказом, перечень, грифы, учёт доступа	0–30 дн.
R15	False negatives детектора → пропуск ПДн в «обезличенном» файле	ч. 1 ст. 431.2 ГК; ст. 6, 19 152-ФЗ	Высокая	Претензия заказчика, регресс; при утечке — солидарная фактура	Метрики полноты в документации, ограничение заверений, обязательная верификация человеком	0–30 дн.
R16	Три параллельных внешних контура (oui, jh, anon.cpcore.ru)	ст. 18.1, 19 152-ФЗ	Средняя	Неучтённые точки обработки; провал инвентаризации на аудите	Инвентаризация, вывод из эксплуатации лишнего, документирование оставшегося	0–21 дн.
R17	Уголовный риск при масштабной утечке или передаче	ст. 272.1 УК РФ (ред. от 26.07.2026)	Низкая	До 4 лет лишения свободы (ч. 1); до 5 лет (ч. 2 — спец. категории, биометрия, ПДн несовершеннолетних)	Устранить R1, R9, R10; фиксировать добросовестность	постоянно

3. Разбор по пунктам охвата

БЛОК А. ПЕРСОНАЛЬНЫЕ ДАННЫЕ

А.1. Передача сырых ПДн на внешний LLM-шлюз — главный риск

Факт. `llm.py:_request_once` формирует `POST {base_url}/chat/completions` с телом, где `messages[1].content` = чанк исходного текста документа. `gliner_remote.py:361` — `POST {base_url}/extract`. Маскирование применяется к тексту **после** возврата спанов от модели. Значит, на шлюз уходят ФИО, паспортные данные, СНИЛС, ИНН, адреса, телефоны в открытом виде.

Правовая квалификация. Три взаимоисключающих варианта:

Вариант 1 — *поручение обработки (ч. 3 ст. 6 152-ФЗ)*. Это единственная конструкция, которая делает схему рабочей. Оператор (заказчик, напр. ИНК) поручает обработку вам; вы, как лицо, осуществляющее обработку по поручению, привлекаете шлюз субпоручением. Требование нормы дословно: в поручении оператора «должны быть определены перечень персональных данных, перечень действий (операций) с персональными данными, которые будут совершаться

лицом, осуществляющим обработку персональных данных, а также **требование об уведомлении оператора о фактах неправомерной или случайной передачи** (предоставления, распространения, доступа) персональных данных». Лицо, осуществляющее обработку по поручению, **не обязано получать согласие субъекта** — основание работает у оператора.

Вариант 2 — передача (предоставление) третьему лицу. Если договора поручения нет, передача квалифицируется как самостоятельное предоставление ПДн лицу, у которого нет ни основания обработки, ни обязательств. Это обработка без правового основания (ст. 6 ч. 1) и нарушение конфиденциальности (ст. 7). **Это ваш текущий статус.**

Вариант 3 — трансграничная передача (ст. 12). Возникает, если сервер шлюза или его апстрим физически вне РФ. Тогда до начала передачи требуется уведомление РКН по ч. 3 ст. 12, а РКН вправе передачу запретить или ограничить (норма действует в редакции ФЗ от 26.07.2026 № 265-ФЗ, который переработал порядок включения стран в перечень обеспечивающих адекватную защиту).

Что обязательно установить про oui.interfonica.cloud — фактологический чек-лист. Пока эти пункты не закрыты письменно, любой вывод остаётся условным:

1. Юридическое лицо — оператор шлюза: наименование, ИНН, юрисдикция регистрации.
2. Физическое размещение вычислительных мощностей: адрес ЦОД, страна. Судя по `usage_log.py:49,106` («тариф Selectel Gemma 4 31B»), инференс идёт на **Selectel** — это российский провайдер, ЦОДы в РФ. Если подтвердится — трансграничной передачи на этом плече нет.
3. Является ли шлюз проксирующим фасадом. Ключевой вопрос: **уходит ли запрос дальше, за пределы контура** (например, в Google AI Studio, OpenRouter, зарубежный API). Если да — появляется трансграничная передача и, возможно, ещё один субобработчик.
4. Логируются ли промпты и ответы на стороне шлюза; срок хранения; кто имеет к ним доступ; используются ли они для дообучения. Требуется **письменный запрет использования данных для обучения**.
5. Есть ли у оператора шлюза собственное уведомление в РКН, назначенный ответственный, политика, аттестат/оценка эффективности.
6. Договор поручения обработки с вами (и, при необходимости, согласие оператора-заказчика на субпоручение).

Есть ли конфигурация, при которой схема незаконна в принципе. Да, две:

- **Апстрим за пределами РФ без уведомления РКН и без основания по ст. 12.** Тогда никакой договор поручения не спасает: нарушается сама процедура трансграничной передачи.
- **Обработка специальных категорий ПДн (ст. 10) или биометрии (ст. 11) без отдельного основания.** Медицинские заключения, справки о судимости, данные о здоровье в документах ИНК вполне вероятны. Для спецкатегорий круг оснований сужен, а санкция за утечку — ч. 16 ст. 13.11 КоАП (10–15 млн ₽ юрлицу [ПРОВЕРИТЬ]).

Меры, делающие схему законной:

[ЗАКОН] Договор поручения обработки со шлюзом с реквизитами по ч. 3 ст. 6: перечень ПДн, перечень операций, конфиденциальность, безопасность по ст. 19, уведомление о неправомерной передаче. [ЗАКОН] Уведомление РКН по ст. 22 с указанием трансграничной передачи, если она есть. [РЕКОМЕНДАЦИЯ] Договорный запрет: не логировать содержимое запросов, не использовать для обучения, хранить не более N секунд, удалять после ответа. Право на аудит. [РЕКОМЕНДАЦИЯ] Инженерно — снизить сам объём передаваемого: детерминированные детекторы (`detectors.py` уже покрывает СНИЛС, ИНН, паспорт, карты) применять **до** обращения к LLM и отправлять на шлюз уже частично маскированный текст. Это не отменяет квалификацию, но радикально снижает величину ущерба при инциденте и хорошо

смотрится в модели угроз. [РЕКОМЕНДАЦИЯ] Стратегически — локальный инференс на мощностях заказчика (см. п. Г.20: для ИНК это, вероятно, единственный проходимый сценарий).

А.2. Прошлый хостинг на Vercel fra1

Факт. web/vercel.json содержит {"regions": ["fra1"]} — Франкфурт, ФРГ. Файл в репозитории **на момент анализа не удалён**. Next.js-роуты /api/anonymize и /api/deanonymize — не статика, а серверные функции: через них проходит тело запроса, то есть файл целиком, и ответ, включающий mapping. Значит, в регионе ЕС происходила как минимум обработка (получение, передача), а технически — и кратковременная запись в память/временные файлы функции.

Квалификация.

[ЗАКОН] **Ч. 5 ст. 18 152-ФЗ (локализация):** при сборе ПДн, в том числе через интернет, оператор обязан обеспечить запись, систематизацию, накопление, хранение, уточнение и извлечение ПДн граждан РФ с использованием баз данных, находящихся на территории РФ.

[СПОРНО] Толкование 1 (мягкое): Vercel-функция выступала транзитным прокси, «база данных» на её стороне не создавалась, следовательно ч. 5 ст. 18 не нарушена — нарушена только ст. 12 (трансграничная передача). Толкование 2 (консервативное, и его следует принять): РКН исходит из того, что первичная запись ПДн должна происходить в РФ; прохождение формы/файла через зарубежный серверless-контур регулятор трактует как первичный сбор за рубежом. **Консервативный вывод: нарушение ч. 5 ст. 18 состоялось.**

[ЗАКОН] **Ч. 3 ст. 12 152-ФЗ:** уведомление РКН о намерении осуществлять трансграничную передачу подаётся до её начала. Не подано — нарушение.

Остаточная ответственность. Да, она есть, но ограничена сроком давности. По ст. 4.5 КоАП общий срок — 60 календарных дней (90 при рассмотрении судьёй) со дня совершения; для ряда составов установлен годичный срок [ПРОВЕРИТЬ конкретно для ч. 8 ст. 13.11 — от этого напрямую зависит, «сгорел» ли эпизод]. **Важнее другое: нарушение локализации носит длящийся характер, и срок исчисляется со дня его обнаружения/прекращения, а не со дня начала.** Пока fra1 в конфигурации — оно продолжается.

Что делать сейчас, по шагам:

1. Немедленно удалить web/vercel.json (или заменить регион на российскую площадку) и удалить проект из Vercel. Зафиксировать коммитом с внятным сообщением.
2. Составить **служебную записку/акт:** период эксплуатации fra1 (с — по), характер трафика, оценка — проходили ли через контур реальные ПДн или только тестовые данные. Если только тестовые (test_samples/) — это принципиально меняет картину, и это надо доказать логам.
3. **Акт об уничтожении** данных на стороне Vercel: запрос на удаление логов и артефактов, письменное подтверждение провайдера, акт по своей форме (требования к порядку уничтожения — приказ РКН от 28.10.2022 № 179 [ПРОВЕРИТЬ реквизиты и актуальность]).
4. **Акт о переносе** инфраструктуры в РФ с датой, реквизитами новой площадки и подтверждающими документами хостера.
5. Решение о ретроспективном уведомлении РКН по ст. 12 — **[СПОРНО]**. За: демонстрация добросовестности, снижение риска при проверке. Против: самораскрытие состава, который иначе мог остаться незамеченным. [РЕКОМЕНДАЦИЯ] Если через fra1 шли реальные документы заказчиков — уведомлять и параллельно готовить позицию о малозначительности; если только тестовые данные — не уведомлять, но иметь готовое доказательное досье.
6. В вендорском пакете для ИНК — раздел «История размещения инфраструктуры» с датой переноса. **Скрывать нельзя:** это ровно тот факт, который вскрывается за десять

минут по истории git, и его сокрытие превращает техническую проблему в вопрос добросовестности поставщика.

А.3. Правовой статус результата: обезличивание или псевдонимизация

Норма. П. 9 ст. 3 152-ФЗ: обезличивание ПДн — «действия, в результате которых становится невозможным без использования дополнительной информации определить принадлежность персональных данных конкретному субъекту персональных данных».

Ваш сервис. mapping.py строит словарь placeholder → original («[PASSPORT_1] → серия 7518, номер 492137»), deanonymize.py восстанавливает текст. Дополнительная информация не уничтожается — она создаётся, возвращается клиенту и делает операцию полностью обратимой. **Это псевдонимизация, а не обезличивание.**

Вывод по статусу выхода. Выходной документ — по-прежнему персональные данные, **пока существует таблица соответствий**. Если маппинг уничтожен и невосстановим, результат приближается к обезличенным данным, но и тогда остаётся риск косвенной идентификации по контексту (должность + структурное подразделение + дата приказа часто идентифицируют человека однозначно даже без ФИО). [РЕКОМЕНДАЦИЯ] В документации формулировать: «маскирование прямых идентификаторов», а не «обезличивание».

Приказ РКН № 996 от 05.09.2013 — отменён. Признан утратившим силу с 1 сентября 2025 г. Действует **приказ Роскомнадзора от 19.06.2025 № 140** «Об утверждении требований к обезличиванию персональных данных и методов обезличивания персональных данных, за исключением случаев, указанных в пункте 9.1 части 1 статьи 6 152-ФЗ» (зарегистрирован в Минюсте 31.07.2025, № 83110; вступил в силу 01.09.2025).

Что в нём значимо для вас:

- **Методы:** введение идентификаторов, изменение состава и семантики ПДн, перемешивание, декомпозиция; допускается применение по отдельности и в совокупности. Ваш подход (замена значения на токен [LABEL_N]) — это «введение идентификаторов». Формально метод из перечня.
- **Запрет совместного хранения** обезличенных и исходных данных. У вас в _JOBS результат и mapping лежат в одной структуре, и в одном ответе клиенту. [РЕКОМЕНДАЦИЯ] Разделить каналы доставки: документ — одним ответом, маппинг — отдельным, с отдельным доступом.
- **Учёт совершаемых действий** — журнал операций обезличивания.
- **Локальные акты** оператора о методах и порядке обезличивания и об используемых информсистемах **не должны быть доступны третьим лицам**. Практическое следствие: подробное описание алгоритма нельзя выкладывать в публичный README.

[СПОРНО] **Обязателен ли приказ № 140 для негосударственного оператора.** Предшественник (№ 996) по названию адресовался ИСПДн, созданным в рамках федеральных целевых программ, и многие толковали его как обязательный только для госоператоров. Приказ № 140 такого сужения в названии не содержит — он общий, с изъятием только для случаев п. 9.1 ч. 1 ст. 6 (обезличивание по требованию Минцифры, отдельно урегулировано ПП РФ от 01.08.2025 № 1154 [ПРОВЕРИТЬ]). **Консервативный вывод: считать обязательным.** Для вас это скорее плюс: соответствие приказу — сильный аргумент в вендорском аудите.

ФЗ от 08.08.2024 № 233-ФЗ ввёл в 152-ФЗ механизм обезличивания по требованию Минцифры и передачи обезличенных данных в государственную информационную систему (п. 9.1 ч. 1 ст. 6). Основные положения заработали с 01.09.2025. Что это меняет для вас: (а) появился формализованный государственный интерес к обезличенным датасетам; (б) обезличенные данные, переданные в ГИС, **не перестают быть персональными** и защищаются в полном объёме; (в) прямой обязанности у вас как у обработчика не возникает — обязанность лежит на

операторе-заказчике, но ваш сервис может стать инструментом её исполнения, и это отдельная продуктовая возможность.

Прямой ответ на вопрос: можно ли рекламировать сервис словом «обезличивание». Нет — в юридическом значении термина по п. 9 ст. 3 152-ФЗ нельзя, пока сервис обратим и вы отдаёте маппинг. Это создаёт риск недостоверного заверения по ст. 431.2 ГК: заказчик, поверивший, что на выходе не-ПДн, снимет защитные меры и при инциденте предъявит убытки вам. Допустимые формулировки: «маскирование персональных данных», «псевдонимизация», «удаление прямых идентификаторов», «подготовка документов к передаче третьим лицам». Если хотите сохранить слово «обезличивание» — только в связке с режимом, где маппинг не создаётся вовсе (см. п. А.4, вариант «безвозвратный режим»).

А.4. Таблица маппинга в оперативной памяти

Факт. `_JOBS` в `server.py` — обычный `dict` в адресном пространстве процесса; `_JOB_TTL_SECONDS = 600`; очистка ленивая, при следующем сабмите (`_sweep_jobs`), фоновый таймера нет. Значит, при отсутствии новых запросов завершённое задание с маппингом может пролежать в памяти **дольше 10 минут**. Маппинг также возвращается клиенту в теле HTTP-ответа.

Снижает ли RAM-хранение риски по сравнению с БД.

[ЗАКОН] **С точки зрения квалификации — нет.** 152-ФЗ определяет обработку (п. 3 ст. 3) как любое действие с ПДн, включая хранение, «независимо от применения средств автоматизации». Закон не различает энергозависимый и энергонезависимый носитель. Информационная система персональных данных (п. 10 ст. 3) — совокупность ПДн в базах данных и обеспечивающих их обработку технологий и средств; ИСПДн у вас есть в любом случае.

[РЕКОМЕНДАЦИЯ] **С точки зрения фактического риска — да, существенно.** Отсутствие персистентного носителя: сокращает окно компрометации до времени жизни процесса; исключает целые классы угроз (кража резервных копий, доступ через СУБД, остаточная информация на дисках); упрощает доказывание уничтожения. Это правильный дизайн — но он должен быть **описан и обоснован в модели угроз**, иначе аудитор его просто не увидит.

Требования к защите, сроку жизни, уничтожению, доказуемости:

- Явный, короткий и **гарантированный** TTL. Ленивую очистку заменить фоновым сборщиком: иначе фактический срок хранения не детерминирован, а вы обязаны его декларировать.
- Отключить `core dumps` процесса (`RLIMIT_CORE=0`), запретить `swap` для страниц с маппингом (`mlock`) — иначе ПДн утекают на диск помимо вашей воли. **Это тот довод, который убивает тезис «мы ничего не храним на диске».**
- Затиранье памяти при удалении (перезапись, а не только `del`). В Python это не гарантируется — честно отразить остаточный риск в модели угроз, а не умалчивать.
- Журнал: `job_id`, время создания, время фактического удаления, без содержимого. Это и есть «доказуемость уничтожения»; акта об уничтожении в классическом виде тут не будет, доказательством служит журнал + описание механизма в регламенте.
- Изоляция процесса: отдельный системный пользователь, `ProtectHome/PrivateTmp` в `systemd`-юните, запрет отладки (`ptrace`).

Что писать в модели угроз (по методике ФСТЭК определения угроз безопасности информации, утв. ФСТЭК России 05.02.2021 [ПРОВЕРИТЬ точное наименование]): актуальными признать угрозы несанкционированного доступа к памяти процесса, утечки через дампы и `swap`, компрометации канала до LLM-шлюза, подмены/перехвата ответа шлюза, доступа к `logs/usage.jsonl`. Неактуальными обосновать: угрозы утечки из СУБД и резервных копий — **при условии** документального подтверждения, что персистентного хранилища нет.

Альтернативы — юридическая оценка:

Вариант	Юридическая оценка
Маппинг возвращается клиенту и не хранится вовсе (stateless)	[РЕКОМЕНДАЦИЯ] Лучший вариант. Вы перестаёте быть хранителем ключа деанонимизации. Ответственность за его сохранность целиком переходит к оператору-заказчику, что фиксируется в договоре. Резко упрощает модель угроз и снимает большую часть возражений ИБ ИНК. Требуется переработки: <code>/jobs/{id}</code> не должен уметь отдавать результат повторно
Шифрование маппинга ключом клиента	Хорошо для сценария «клиент вернётся за деанонимизацией позже». Юридически: зашифрованные ПДн остаются ПДн, но при отсутствии ключа у вас риск ущерба стремится к нулю, а в модели угроз угроза раскрытия обоснованно признаётся неактуальной. Требуется управления ключами — а это уже вопрос СКЗИ (см. Б.10)
Текущий: RAM + TTL + отдача клиенту	Промежуточный. Работоспособен, но требует всей обвязки выше (mlock, no-dump, детерминированный TTL, журнал) и слабее выглядит на аудите
Безвозвратный режим (маппинг не создаётся)	Отдельный режим продукта. Единственный, при котором можно юридически корректно говорить «обезличивание». [РЕКОМЕНДАЦИЯ] Сделать его и продавать как «режим ст. 3 п. 9»

A.5. Файл logs/usage.jsonl

Факт. `usage_log.py:98` — путь <корень репо>/logs/usage.jsonl. Записи `kind: "request_total"` содержат: `ts`, `request_id`, `filename`, `chars`, `pages`, `seconds`, `calls`, `tokens_by_kind`, `cost_rub`, `stages`. Записи `kind: <call>` содержат `model`, токены, `ok` и **`error: str(exc)`**. В `llm.py:421` при `ne-2xx` формируется исключение с телом ответа `resp_body[:200]` — то есть в поле `error` может попасть фрагмент ответа шлюза; если шлюз эхом возвращает часть запроса (что типично для ошибок валидации), в лог попадёт фрагмент документа с ПДн.

Что допустимо хранить. Технические метрики без содержания: `request_id` (случайный, не производный от имени файла), объём в символах/страницах, количество и длительность вызовов, модель, токены, стоимость, коды ошибок, категории найденных сущностей **без значений** (например, «PASSPORT: 3 шт.»).

Что превращает лог в неучтённую ИСПДн:

- filename в открытом виде.** Имена документов в корпоративном обороте регулярно содержат ФИО. Это ПДн. [РЕКОМЕНДАЦИЯ] заменить на `sha256(filename)[:16]` + расширение, оригинал не сохранять.
- error без санитизации.** [РЕКОМЕНДАЦИЯ] не писать тело ответа в лог; писать только HTTP-статус и класс исключения. Это правка на пару строк, а риск снимает целиком.
- Любое добавление в будущем текста спанов, фрагментов документа, маппинга — категорический запрет, зафиксировать в CONTRIBUTING/регламенте.

Требования к логам как таковым:

[ЗАКОН] Если лог содержит ПДн — он часть ИСПДн: включается в перечень обрабатываемых ПДн, в модель угроз, на него распространяются меры приказа ФСТЭК № 21 (в частности группа «регистрация событий безопасности»), устанавливается срок хранения и порядок уничтожения по ст. 21 152-ФЗ. [ИБ-ЗАКАЗЧИК] Служба ИБ ИНК почти наверняка потребует: разделение журналов ИБ и журналов приложения, защиту журналов от модификации, срок хранения событий безопасности не менее 6 месяцев (типовое требование), контроль доступа и передачу событий в СИЕМ/ГосСОПКА. [РЕКОМЕНДАЦИЯ] Целевая конфигурация: `usage.jsonl` — только технические метрики, без ПДн, срок хранения 12 месяцев для биллинга; отдельный журнал ИБ

(доступ, аутентификация, ошибки авторизации) с более строгим режимом; ротация; права 0600, отдельный пользователь.

А.6. Роли сторон в цепочке «ИНК → сервис → LLM-шлюз»

Распределение ролей:

Звено	Роль по 152-ФЗ	Основание
ИНК	Оператор (п. 2 ст. 3) — определяет цели и состав обрабатываемых ПДн	Собственные основания: трудовые отношения, договоры, закон
Вы	Лицо, осуществляющее обработку по поручению оператора (ч. 3 ст. 6)	Договор поручения с ИНК
Оператор шлюза	Лицо, осуществляющее обработку по субпоручению	Договор поручения с вами + согласие ИНК

[ЗАКОН] **Допустимо ли субпоручение.** Прямого запрета в 152-ФЗ нет, и практика его допускает — но только с ведома и согласия оператора. Молчаливое привлечение субобработчика — самостоятельное нарушение и, что практически важнее, основание для расторжения договора с ИНК.

Что должно быть в согласии оператора на привлечение третьего лица:

- Идентификация субобработчика: наименование, ИНН, адрес, место фактической обработки.
- Перечень ПДн, передаваемых субобработчику, и перечень операций.
- Территория обработки (обязательно — РФ; если нет, отдельно оформляется трансграничная передача).
- Запрет на дальнейшее субпоручение без согласия оператора.
- Обязанность соблюдать требования ст. 18.1 и 19 152-ФЗ не ниже, чем у вас.
- Обязанность уведомлять о фактах неправомерной или случайной передачи.
- Право оператора на аудит субобработчика (напрямую или через вас).
- Порядок и сроки уничтожения ПДн у субобработчика.

Ответственность каждого звена.

[ЗАКОН] Ч. 5 ст. 6 152-ФЗ: **перед субъектом ПДн ответственность за действия лица, которому поручена обработка, несёт оператор.** Лицо, осуществляющее обработку, несёт ответственность **перед оператором.** То есть субъект (работник ИНК) предъявит претензию ИНК, ИНК заплатит и придёт с регрессом к вам, вы — к шлюзу. Ваш практический вывод: **вы регрессное звено, и предел вашей ответственности определяется не законом, а договором.** Отсюда критическая важность п. «Ограничение ответственности» (см. раздел 6).

[ЗАКОН] Административная ответственность по ст. 13.11 КоАП при этом **самостоятельна для каждого звена** — оператор не «прикрывает» обработчика. РКН вправе привлечь вас напрямую.

А.7. Уведомление Роскомнадзора об обработке ПДн

[ЗАКОН] **Нужно подавать.** Ст. 22 152-ФЗ. Исключения по ч. 2 ст. 22 узкие: ПДн в ГИС, созданных в целях защиты безопасности и правопорядка; обработка исключительно на бумажных носителях; обработка для обеспечения безопасности на транспорте. Ни одно к вам

не относится. Обработка по поручению от освобождения не даёт: обработчик — самостоятельное лицо, обрабатывающее ПДн.

В каком качестве. Как **оператор** — в отношении собственных ПДн (клиенты, контрагенты, работники) и как лицо, осуществляющее обработку по поручению — в отношении данных заказчиков. [ПРАКТИКА] В форме уведомления РКН предусмотрено указание на обработку по поручению; поле нужно заполнить, иначе картина обработки будет недостоверной.

Что указывать по трансграничной передаче. Отдельный блок формы. Если шлюз в РФ — указывается отсутствие трансграничной передачи, но это утверждение должно быть подтверждено документами от оператора шлюза, иначе вы подаёте недостоверные сведения. Если апстрим за рубежом — перечисляются страны, и до начала передачи подаётся **отдельное** уведомление по ч. 3 ст. 12.

Сроки и ответственность. Уведомление подаётся до начала обработки. Сведения появляются в реестре в течение 30 дней. [ЗАКОН] Ответственность за неподачу — ч. 10 ст. 13.11 КоАП: для юрлиц **100 000 – 300 000 Р** [ПРОВЕРИТЬ по действующей редакции]. При изменении сведений — обязанность уведомить об изменениях.

А.8. Основание обработки и субъекты ПДн, с которыми у вас нет отношений

Постановка проблемы верна и она содержательна. Субъекты — люди, упомянутые в чужих документах: работники ИНК, контрагенты, третьи лица. Вы их не знаете, согласия у них не брали и взять не можете.

Как это легализуется. Ответ: чужим основанием.

[ЗАКОН] Работает основание **оператора (ИНК)**: трудовые отношения (п. 5 ч. 1 ст. 6 — исполнение договора, стороной которого является субъект), исполнение возложенных законом обязанностей (п. 2 ч. 1 ст. 6), законные интересы оператора (п. 7 ч. 1 ст. 6). При поручении обработки по ч. 3 ст. 6 **лицо, осуществляющее обработку, не обязано получать отдельное согласие субъекта** — основание не «перевыдаётся», а продолжает действовать. Это ключевая конструкция: без модели поручения ваш сервис вообще нелегализуем, потому что своего основания у вас нет и быть не может.

Нужно ли уведомлять субъектов. [ЗАКОН] Обязанность информировать субъекта (ст. 18) лежит на **операторе**. У вас как у обработчика такой обязанности нет. Но: оператор обязан указать в своей политике и в уведомлениях работникам, что обработка может поручаться третьим лицам. [РЕКОМЕНДАЦИЯ] Включите в договор с ИНК заверение заказчика о том, что он выполнил обязанности по информированию субъектов и располагает надлежащим основанием обработки — это перекладывает риск туда, где он и должен быть.

Применимые исключения. Отдельного исключения «для сервисов обработки документов» в законе нет. Иногда ссылаются на п. 10 ч. 1 ст. 6 (общедоступные данные) — к корпоративным документам **неприменимо**, не используйте этот довод.

Что должно быть в вашей Политике обработки ПДн (ч. 2 ст. 18.1): правовые основания и цели обработки; категории субъектов (обязательно указать: лица, ПДн которых содержатся в документах, обрабатываемых по поручению операторов); категории ПДн; порядок и условия обработки; сведения о поручении обработки третьим лицам с указанием субобработчиков; сроки обработки и хранения; порядок уничтожения; порядок реализации прав субъектов и маршрутизации обращений; актуальные сведения о трансграничной передаче; сведения об ответственном за организацию обработки; применяемые меры по ст. 18.1 и 19. Политика публикуется в открытом доступе (ч. 2 ст. 18.1).

[РЕКОМЕНДАЦИЯ] Отдельно опишите **маршрутизацию обращений субъектов**: если к вам обратился человек, чьи ПДн оказались в документе заказчика, вы не вправе ни подтвердить, ни

опровергнуть факт обработки — вы обязаны перенаправить обращение оператору. Это должно быть прописано и в политике, и в договоре, и в регламенте поддержки.

А.9. Точность детекции как правовой риск

Факт. ML-детекция (LLM + GLiNER + слои ревью в review.py) статистична по природе. Полноты 100% не будет никогда. eval_benchmark.py в проекте есть — значит, метрики измеримы, и это ваш главный актив в этом вопросе.

Отвечаете ли вы за пропуск. [СПОРНО], и ответ зависит целиком от формулировок договора.

Толкование 1 (обязательство результата). Если вы заявляете «сервис обезличивает документы», предмет договора — достижение результата. Пропуск ПДн = ненадлежащее исполнение (ст. 393 ГК) + недостоверное заверение (ст. 431.2 ГК). Утечка у заказчика из-за вашего пропуска → регресс на полную сумму его штрафа, а это до 15 млн ₽ по ч. 14 ст. 13.11 КоАП, а при повторе — оборотный штраф до 500 млн ₽.

Толкование 2 (обязательство усилий). Если предмет — «автоматизированное выявление и маскирование ПДн с заявленной полнотой не менее X% на эталонном наборе, требующее верификации оператором», то ваша обязанность — обеспечить заявленную полноту, а финальная ответственность за выпуск документа лежит на заказчике.

[РЕКОМЕНДАЦИЯ] **Всегда договаривайтесь по толкованию 2 и стройте продукт под него.**

Как ограничить договором:

- Предмет: «автоматизированное **выявление и маскирование** прямых идентификаторов», а не «обезличивание документов».
- Метрики: приложить методику измерения, эталонный набор, измеренные precision/recall по категориям сущностей, дату измерения, версию модели. Заявлять только то, что измерено на воспроизводимом наборе.
- Обязательный этап верификации человеком со стороны заказчика перед выпуском документа наружу — зафиксировать как **условие надлежащего использования результата**, а не как рекомендацию.
- Прямое исключение: система не гарантирует выявление ПДн, выраженных косвенно, в нестандартной форме, в изображениях, в сканах без текстового слоя (что для вашего rурpdf-извлечения — реальный и частый случай), в нераспознанных вложениях.
- Ограничение ответственности суммой вознаграждения за период (см. раздел 6).

Какие заверения давать нельзя — список категорических запретов:

- «Гарантируем полное удаление всех персональных данных» / «100% обезличивание».
- «Документ после обработки не содержит персональных данных».
- «Соответствует требованиям 152-ФЗ» без указания, каким именно и в какой части.
- «Обезличивание по ст. 3 п. 9 152-ФЗ» — пока сервис обратим, это ложь.
- Любая цифра полноты, не подтверждённая протоколом измерения.

Нужны ли метрики полноты в документации. [ЗАКОН] — нет. [ИБ-ЗАКАЗЧИК] — **да, обязательно:** без них ИНК не пройдёт внутреннюю процедуру приёма, а вы не сможете разграничить ответственность. [РЕКОМЕНДАЦИЯ] Публиковать: метрики по категориям, размер и состав эталонного набора, дату и версию, известные ограничения. Честные метрики защищают лучше, чем их отсутствие: заявленная и подтверждённая полнота 96% — это выполненное обязательство, а «мы всё удаляем» при найденном пропуске — недостоверное заверение.

БЛОК Б. БЕЗОПАСНОСТЬ И ЛИЦЕНЗИРОВАНИЕ ДЕЯТЕЛЬНОСТИ

Б.10. Уровень защищённости ИСПДн, требования ФСТЭК и ФСБ

Нормативная рамка. Ст. 18.1 152-ФЗ (организационные и правовые меры), ст. 19 (обеспечение безопасности), ПП РФ от 01.11.2012 № 1119 (уровни защищённости), приказ ФСТЭК России от 18.02.2013 № 21 (состав и содержание мер, ред. от 14.05.2020), приказ ФСБ России от 10.07.2014 № 378 (меры при использовании СКЗИ).

Определение уровня защищённости — обоснование. По ПП № 1119 уровень определяется тремя переменными: категория обрабатываемых ПДн, тип актуальных угроз, количество субъектов.

1. **Категория ПДн.** Базово — иные ПДн (ФИО, должности, контакты, реквизиты документов). **Но:** ваш сервис принимает произвольные документы заказчика и, судя по меткам в README.md и МАТЧАСТЬ.md (PASSPORT, SNILS, OMS, MILITARY_ID, BIRTH_CERTIFICATE, DRIVER_LICENSE), рассчитан на документы, где **могут** встретиться сведения о состоянии здоровья (полис ОМС, медицинские заключения) — то есть специальные категории по ст. 10. Консервативно нужно исходить из **специальных категорий**.
2. **Тип угроз.** Угрозы 3-го типа (не связанные с недеklarированными возможностями системного и прикладного ПО) — обосновываемо для типового Linux + Python-стека. Угрозы 2-го типа придётся признать актуальными, если в модели угроз вы не сможете обосновать доверенность прикладного ПО, включая **внешнюю LLM**, поведение которой вы не контролируете. [СПОРНО] — обоснование выбора должно быть в модели угроз, и на аудите его будут проверять именно здесь.
3. **Количество субъектов.** Менее 100 000 на старте, более 100 000 при работе с крупным заказчиком уровня ИНК.

Вывод:

- [РЕКОМЕНДАЦИЯ] Для собственной ИСПДн (клиенты, работники, контрагенты) при угрозах 3-го типа и иных ПДн — **УЗ-4**.
- Для продуктовой ИСПДн (обработка документов заказчиков) при консервативном допущении спецкатегорий и угроз 3-го типа — **УЗ-2**; при иных ПДн и менее 100 000 субъектов — **УЗ-3**. [РЕКОМЕНДАЦИЯ] Проектируйте под **УЗ-2**. Разница принципиальна: см. ниже.
- Формально уровень фиксируется **актом определения уровня защищённости**, который вы обязаны иметь и который у вас попросят первым.

Приказ ФСТЭК № 21. Устанавливает базовые наборы мер для каждого УЗ по 15 группам: идентификация и аутентификация, управление доступом, ограничение программной среды, защита машинных носителей, регистрация событий безопасности, антивирусная защита, обнаружение вторжений, контроль (анализ) защищённости, обеспечение целостности, обеспечение доступности, защита среды виртуализации, защита технических средств, защита ИС и её компонентов, выявление инцидентов, управление конфигурацией. Базовый набор адаптируется и дополняется по результатам модели угроз.

Когда возникает требование сертифицированных СЗИ.

[ЗАКОН] Ключевая развилка приказа № 21: для **УЗ-1 и УЗ-2** применяются средства защиты информации, **прошедшие оценку соответствия** требованиям ФСТЭК (на практике — сертификация). Для **УЗ-3 и УЗ-4** допустимо применение любых средств, если они нейтрализуют актуальные угрозы, а оценка соответствия может проводиться в форме испытаний или приёмки самим оператором.

Практический вывод: **если вы удержите УЗ-3, сертифицированные СЗИ не обязательны и это экономит вам сотни тысяч рублей и месяцы. Если уровень окажется УЗ-2 — придётся закупать сертифицированные средства.** [РЕКОМЕНДАЦИЯ] Это второй по значимости продуктовый рычаг после stateless-маппинга: явно запретить офертой загрузку документов со

спецкатегориями ПДн и биометрией, вынести это в предмет договора и в интерфейс. Тогда УЗ-3 обосновывается честно.

Приказ ФСБ № 378 (СКЗИ). [ЗАКОН] Применяется **только если** для нейтрализации актуальных угроз вы используете криптографию. Обязанность использовать СКЗИ возникает, если угроза перехвата на канале признана актуальной и нейтрализуется криптографически. Уровень защищённости определяет требуемый класс СКЗИ (КС1/КС2/КС3/КВ/КА).

[СПОРНО] Является ли TLS до LLM-шлюза «применением СКЗИ» в смысле приказа № 378. Толкование мягкое: обычный TLS с зарубежными алгоритмами — не СКЗИ по российской классификации, и приказ № 378 не применяется. Толкование консервативное: канал передачи ПДн за пределы контролируемой зоны должен защищаться сертифицированным СКЗИ класса не ниже КС1, а при УЗ-2 — КС2 и выше; на практике это ГОСТ-VPN (КриптоПро, С-Терра, ViPNet). [ИБ-ЗАКАЗЧИК] **Служба ИБ ИНК почти наверняка потребует ГОСТ-канал** до внешних компонентов или вообще запретит вынос данных за периметр. Закладывайте это в архитектуру заранее.

Б.11. Нужна ли лицензия ФСТЭК

Здесь действительно частая ошибка в обе стороны, поэтому разберу отдельно два вопроса.

Как оператору ПДн, защищающему собственную ИСПДн.

[ЗАКОН] Лицензирование деятельности по технической защите конфиденциальной информации (ТЗКИ) регулируется ПП РФ от 03.02.2012 № 79. Лицензируется **деятельность по оказанию услуг** третьим лицам, а не защита собственной информации.

[СПОРНО] Историческая позиция ФСТЭК (письмо от 18.06.2010 № 240/2/2520) допускала прочтение, что и работы «для собственных нужд» требуют лицензии. Преобладающая современная практика: **оператор, защищающий свою ИСПДн собственными силами, лицензию не получает**; она нужна тому, кто делает это для других. Консервативное прочтение: если вы выполняете работы по защите информации в информационной системе **заказчика** (устанавливаете СЗИ, аттестуете, сопровождаете) — лицензия нужна.

Вывод для вас: [РЕКОМЕНДАЦИЯ] **Как оператору собственной ИСПДн — лицензия ТЗКИ не требуется.** Она потребуется, если вы начнёте оказывать ИНК услуги по защите информации в контуре ИНК (внедрение, настройка, сопровождение СЗИ на их площадке). Простая поставка SaaS-сервиса обработки документов — не лицензируемая деятельность.

Как разработчику.

[ЗАКОН] Лицензия на разработку и производство средств защиты конфиденциальной информации (ПП РФ от 03.03.2012 № 171 [ПРОВЕРИТЬ реквизиты]) требуется тому, кто разрабатывает и производит **средства защиты информации** как таковые.

[СПОРНО] Является ли анонимизатор средством защиты информации. Толкование 1 (моё основное): нет. Это средство обработки документов, реализующее прикладную функцию маскирования; оно не выполняет функций СЗИ в классификации ФСТЭК (не является средством контроля доступа, антивирусом, СОВ, межсетевым экраном, средством доверенной загрузки). Толкование 2 (консервативное): если вы позиционируете продукт как **средство обеспечения безопасности ПДн** и заказчик учитывает его в качестве меры защиты по приказу ФСТЭК № 21 (например, в группе мер по обезличиванию), возникает риск переквалификации.

[РЕКОМЕНДАЦИЯ] Управляйте этим риском **позиционированием**: не называйте продукт «средством защиты информации», не заявляйте, что он реализует меры приказа ФСТЭК № 21. Называйте: «система автоматизированной подготовки документов / маскирования персональных данных». Это не уловка — это точное описание того, что код делает.

Итог по п. 11: лицензии ФСТЭК не нужны ни как оператору, ни как разработчику, **при условии** правильного позиционирования и отказа от оказания услуг по защите информации в чужом

контуре. Это, вероятно, самая приятная новость в документе — но она держится на формулировках, и потому её нужно закрепить в маркетинге и договоре, а не просто принять к сведению.

Б.12. Что на самом деле означает «сервер с лицензией по 152-ФЗ» у Интерфоники

Прямо: формулировка «сервер с лицензией по 152-ФЗ» юридически не существует. Закон не выдаёт лицензий серверам. За этой фразой у провайдеров обычно стоит одно из трёх, и разница между ними принципиальна:

1. **Аттестат соответствия** ЦОД или сегмента инфраструктуры требованиям безопасности информации — реальный документ с указанием класса/уровня, области действия и срока.
2. **Заключение о соответствии / акт оценки эффективности** принятых мер по ст. 19 152-ФЗ — слабее аттестата, часто выдаётся самим провайдером или его подрядчиком.
3. **Лицензия ФСТЭК на ТЗКИ у провайдера** — говорит о праве провайдера оказывать услуги по защите информации, но **ничего не говорит о защищённости конкретно вашей стойки.**

Отдельно: заявление «инфраструктура соответствует 152-ФЗ до УЗ-3» (типовая формулировка российских провайдеров, в т.ч. Selectel) означает, что **на уровне инфраструктуры** обеспечены условия, при которых оператор может достичь УЗ-3. Ответственность за уровень приложения и данных остаётся на вас целиком.

Какие документы вы обязаны получить от Интерфоники и приложить в вендорский пакет:

#	Документ	Зачем
1	Договор поручения обработки ПДн (или раздел в договоре хостинга) по ч. 3 ст. 6 152-ФЗ	Без него хостер — неоформленный субобработчик. Блокирующий пункт
2	Аттестат соответствия ЦОД/сегмента с указанием области действия и срока	Подтверждение уровня инфраструктуры
3	Лицензия ФСТЭК на ТЗКИ (копия) + выписка из реестра лицензий	Подтверждение правоспособности провайдера
4	Документ, подтверждающий физическое размещение оборудования в РФ: адрес ЦОД, договор аренды/размещения	Доказательство соблюдения ч. 5 ст. 18
5	Выписка из реестра операторов ПДн (уведомление провайдера в РКН)	Подтверждение легальности звена
6	Политика обработки ПДн провайдера, порядок реагирования на инциденты, SLA с временем уведомления об инциденте	Стыковка с вашим регламентом (24/72 ч по ст. 21)
7	Порядок и подтверждение уничтожения данных при расторжении	Ст. 21 152-ФЗ

#	Документ	Зачем
8	Условия по субподряду : привлекает ли провайдер третьих лиц (важно для <code>oui.interfonica.cloud</code> , если инференс идёт на чужих мощностях, например Selectel)	Вскрывает четвёртое звено цепочки
9	Право на аудит / результаты независимой оценки	[ИБ-ЗАКАЗЧИК]

Достаточно ли этого для заказчика уровня ИНК. [ИБ-ЗАКАЗЧИК] **Само по себе — нет.** Крупный нефтегазовый заказчик смотрит не на бумаги хостера, а на вашу собственную систему защиты: акт УЗ, модель угроз, аттестат или заключение по **вашей** ИСПДн, результаты пентеста, наличие ответственного, регламент реагирования на инциденты, подключение к ГосСОПКА (если заказчик — субъект КИИ, он будет требовать совместимости процессов реагирования). Документы провайдера — необходимое, но далеко не достаточное условие.

Б.13. Beamer-токен, nginx, лимит 50 МБ, таймаут 320 с

Разбираю по элементам — и здесь есть находки хуже, чем перечисленные в вопросе.

Элемент	Оценка	Что проверит ИБ заказчика
Beamer-токен подставляется на сервере, в браузер не попадает	Правильно. <code>web/app/api/_shared.ts</code> использует <code>process.env.ANONYMIZER_BACKEND_KEY</code> серверно	Где хранится секрет (переменная окружения vs. секрет-менеджер), ротация, кто имеет доступ, не попадает ли в логи сборки
Входной контур Python-сервера без аутентификации	Находка. Серьёзная. В <code>server.py</code> проверки входящего <code>Authorization</code> не обнаружено; Beamer-токены в коде — только исходящие, к LLM и GLiNER	Блокирующий пункт. Требование: аутентификация каждого запроса, желательно mTLS или подписанные токены
Access-Control-Allow-Origin: * (<code>server.py:362</code>)	Находка. В связке с отсутствием аутентификации означает: любой сайт может отправить документ на ваш бэкэнд, если до него есть сетевой доступ	Блокирующий пункт. Требование: явный allowlist источников
Привязка к 127.0.0.1:8010 + nginx	Хорошо — это и есть основная компенсирующая мера, закрывающая две строки выше. Но она должна быть описана в модели угроз , иначе аудитор увидит только <code>CORS: *</code>	Конфигурация nginx, отсутствие альтернативных путей до порта, сегментация
client_max_body_size 50m	Мера против DoS. Разумно	Наличие rate limiting (в коде не найден), защита от загрузки архивных бомб (<code>jszip</code> на фронте — отдельный вектор), проверка типов файлов

Элемент	Оценка	Что проверит ИБ заказчика
Таймаут 320 с	Функционально оправдан (LLM медленный), но это долгоживущее соединение	Защита от медленных клиентов (slowloris), ограничение числа одновременных заданий, поведение при исчерпании пула
_JOBS в памяти, job_id в URL	Если job_id предсказуем или недостаточно энтропийен — прямой доступ к чужому результату. server.py не проверяет принадлежность задания клиенту	Блокирующий пункт: IDOR. Требование: привязка задания к аутентифицированному субъекту
Отсутствие TLS между nginx и Python	Внутри хоста через loopback — приемлемо. При выносе на отдельный узел — обязателен TLS, [ИБ-ЗАКАЗЧИК] вероятно ГОСТ	Схема сегментации
logs/usage.jsonl с именами файлов	См. А.5	Права на файл, ротация, состав полей

[РЕКОМЕНДАЦИЯ] Три правки закрывают большую часть блокирующих пунктов: (1) обязательная проверка Authorization на входе Python-сервера; (2) Access-Control-Allow-Origin из белого списка; (3) привязка job_id к субъекту + криптостойкий идентификатор. Это работа на день-два, а на аудите — разница между «отклонено» и «принято с замечаниями».

БЛОК В. ЛИЦЕНЗИИ НА КОМПОНЕНТЫ

В.14. Google Gemma — Terms of Use

Главная находка, меняющая весь блок: **Gemma 4 распространяется под Apache License 2.0, а не под Gemma Terms of Use.** Официальная страница Gemma Terms of Use (ред. от 01.04.2026) в первой же строке отсылает: «For Gemma 4 terms, see the Gemma 4 license» → ai.google.dev/gemma/apache_2 → полный текст Apache-2.0. Приложение к Gemma ToU перечисляет модели, на которые ToU распространяется (Gemma 1, 1.1, 2, 3, 3n, PaliGemma, ShieldGemma, CodeGemma и др.) — **Gemma 4 в этом перечне отсутствует.**

В вашем коде фигурируют gemma4:12b, google/gemma-4-12b-qat и тариф «Selectel Gemma 4 31B» — то есть **семейство Gemma 4.**

Отсюда два сценария:

Сценарий А — шлюз обслуживает Gemma 4 (наиболее вероятный). Применяется Apache-2.0. Никакой Prohibited Use Policy, никакой обязанности транслировать условия конечному пользователю, никакой цепочки согласий. Обязательства сводятся к стандартным §4(a)–(d): при **распространении** — копия лицензии, пометка изменённых файлов, сохранение уведомлений, воспроизведение NOTICE. При использовании через API вы модель вообще не распространяете, поэтому и эти обязательства не возникают. **Практически: вопрос закрыт.**

Сценарий Б — шлюз на самом деле обслуживает Gemma 3 или иную модель из Приложения. Тогда применяется Gemma Terms of Use, и картина другая:

- *Коммерческое использование в SaaS* — **разрешено.** Отдельного соглашения с Google не требуется. Определение «Distribution» в п. 1.1(b) прямо включает предоставление

функциональности Gemma как hosted service через API, web access и иные удалённые средства.

- *Prohibited Use Policy* инкорпорирована по ссылке (п. 3.2.1) и обязательна для соблюдения вами и вашими пользователями.
- *Передача условий конечному пользователю* — **да, требуется**. П. 3.1(1): вы обязаны включить ограничения использования из п. 3.2 как **принудительно исполнимое положение** в любое соглашение, регулирующее использование Gemma (то есть в вашу оферту/договор с ИНК), и уведомить пользователей. П. 3.1(2): предоставить получателям копию Gemma ToU.
- *Требование NOTICE-файла* (п. 3.1(4)) применяется ко всем распространениям, **кроме** hosted service. Ваш случай — hosted service, значит NOTICE по Gemma не обязателен, но пункт про перенос ограничений в оферту — обязателен.
- *Выводы модели (Outputs)* — п. 3.3: Google не заявляет прав на выводы; ответственность за выводы и их последующее использование целиком на вас и ваших пользователей. Важно: п. 1.1(е) прямо оговаривает, что **Outputs не считаются Model Derivatives**, поэтому обнаруженные моделью спаны ПДн не тянут за собой лицензионных обязательств по производным моделям.

Влияет ли то, что модель вызывается через посредника-шлюз. [СПОРНО] Толкование 1: лицензионные отношения по Gemma возникают у того, кто *использует, воспроизводит, распространяет* модель — то есть у оператора шлюза; вы — потребитель его услуги, и ToU на вас не распространяется. Толкование 2 (консервативное): п. 2.2 говорит об использовании «Gemma Services», а п. 1.1(b) относит к Distribution предоставление функциональности через API; вы, перепродавая результат работы Gemma в своём SaaS, участвуете в цепочке и обязаны соблюдать п. 3.2. [РЕКОМЕНДАЦИЯ] В сценарии Б — принять консервативное толкование, это дёшево: один абзац в оферте.

Действия: 1. Получить от оператора шлюза **письменное подтверждение**, какая именно модель обслуживает эндпоинт (наименование, версия, лицензия) и что он правомочен предоставлять её как сервис. Это единственное действие, которое закрывает пункт. 2. Устранить разнбой дефолтов в коде (gemma4:12b vs qwen3.5:9b): аудитор задаст вопрос именно о нём. 3. [РЕКОМЕНДАЦИЯ] На всякий случай включить в оферту абзац с ограничениями использования и ссылкой на Prohibited Use Policy — стоит ноль, снимает сценарий Б целиком.

В.15. Словари OpenCorpora через rymorphy3

Факт по коду. detectors.py:1039-1085 строит морфологический словарь через rymorphy3 → rymorphy2 → natasha.MorphVocab (который внутри оборачивает те же данные). Пакет rymorphy3-dicts-ru собирается из данных **OpenCorpora**.

Лицензионная конструкция двухслойная: код rymorphy3 — MIT; данные словарей — **Creative Commons Attribution-ShareAlike** (для OpenCorpora обычно указывается CC BY-SA; конкретная версия — 3.0 или 4.0 — [ПРОВЕРИТЬ] по файлу лицензии в установленном пакете).

Совместимость с раздачей вашего кода под Apache-2.0.

[ЗАКОН] CC BY-SA и Apache-2.0 совместимы **в одном направлении и при одном условии:** словари должны оставаться отдельным произведением, а не встраиваться в ваш код. Ключевое различие — «distribution» против «mere aggregation»:

- **Если вы не распространяете словари** (пользователь ставит `pip install rymorphy3-dicts-ru` сам, зависимость объявлена в `requirements.txt` — **это ваш текущий случай**): обязательства ShareAlike **не возникают**. Вы ничего не распространяете. Риск copyleft-эффекта — **нулевой**.
- **Если вы поставляете дистрибутив с вшитыми словарями** (Docker-образ, установщик, on-prem-сборка для ИНК — а к этому вы, вероятно, придёте): вы

распространяете произведение под CC BY-SA. Тогда: (а) обязательна атрибуция OpenCorpora с указанием лицензии и ссылки; (б) ShareAlike требует, чтобы **адаптации словарей** распространялись под той же лицензией. Ваш Python-код словари не адаптирует — он их читает. Это классический случай **коллекции/агрегации**, при котором ShareAlike на ваш код не распространяется.

Прямой ответ: [РЕКОМЕНДАЦИЯ] **Риск copyleft-эффекта на ваш код отсутствует**, при условии что вы не модифицируете сами словарные данные. Если начнёте дополнять словарь своими словоформами и распространять его — производный словарь придётся отдать под CC BY-SA (сам код останется под Apache-2.0).

Что сделать: 1. Файл `THIRD_PARTY_LICENSES.md` с явной секцией: «Morphological dictionaries — OpenCorpora, CC BY-SA, источник, версия». 2. В `NOTICE` — строка атрибуции. 3. **До первой on-prem-поставки** — проверить точную версию CC BY-SA в `rumorphy3-dicts-ru` и продублировать текст лицензии в дистрибутив. 4. `custom_terms.txt` и `glossary.py` — убедиться, что они не содержат производных от OpenCorpora данных.

B.16. GLiNER от knowledgator

Установлено фактически. Карточка модели `knowledgator/gliner-relex-multi-v1.0` на Hugging Face указывает **License: apache-2.0**. Размер 0.3B параметров, поддержка ONNX-экспорта.

Сравнение с запасным вариантом:

	knowledgator/gliner-relex-multi-v1.0 (используется)	urchade/gliner_multi-v2.1 (альтернатива в коде)
Лицензия	Apache-2.0	Apache-2.0
Коммерческое использование	Разрешено	Разрешено
Обязательства	§4(a)–(d) Apache-2.0 при распространении весов	То же
Функциональность	NER + извлечение отношений в одном проходе	Только NER
Риск	Низкий	Низкий

Вывод: лицензионных препятствий нет ни у одного варианта. [РЕКОМЕНДАЦИЯ] Отдельно проверьте лицензию **базового энкодера**, на котором обучен чекпойнт (у GLiNER-моделей это часто DeBERTa/mDeBERTa от Microsoft под MIT, но встречаются и другие) — обязательства базовой модели наследуются. Также проверьте лицензию **обучающих данных**, если планируете дообучение: некоторые датасеты для GLiNER имеют non-commercial ограничения, и это распространяется на дообученный чекпойнт.

Отдельно, важное для блока А: библиотека `gliner` при загрузке `from_pretrained` **обращается к Hugging Face Hub** (`gliner_ner.py:83`). В on-prem-поставке для ИНК это будет означать сетевой доступ наружу — блокирующий пункт для изолированного контура. Веса нужно поставлять в комплекте.

В.17. Permissive-компоненты

Компонент	Лицензия [ПРОВЕРИТЬ по установленным версиям]	Обязательства
python-docx	MIT	Сохранение уведомления об авторских правах и текста лицензии
lxml	BSD-3-Clause (ядро libxml2/libxslt — MIT)	Уведомление, запрет использования имён авторов для продвижения
openpyxl	MIT	Уведомление
xlrd	BSD-3-Clause	Уведомление
olefile	BSD-2-Clause	Уведомление
pypdf	BSD-3-Clause	Уведомление
transformers	Apache-2.0	§4(a)–(d), включая NOTICE
huggingface-hub	Apache-2.0	§4(a)–(d)
torch	BSD-3-Clause (+ отдельные условия для CUDA-сборок)	Уведомление; отдельно проверить условия NVIDIA для CUDA-компонентов при распространении образа
Next.js	MIT	Уведомление
React / React-DOM	MIT	Уведомление
jszip	MIT или GPLv3 (двойная лицензия — выбрать MIT явно)	Уведомление; зафиксировать выбор MIT в документации
Streamlit (опционально)	Apache-2.0	§4(a)–(d)

Нужен ли NOTICE-файл. [ЗАКОН] Да, если вы распространяете дистрибутив. Apache-2.0 §4(d) прямо требует: если распространяемое произведение включает файл NOTICE, производные должны воспроизводить содержащиеся в нём уведомления об атрибуции. Поскольку в вашем стеке есть Apache-2.0-компоненты (transformers, huggingface-hub, GLiNER-веса), **при поставке дистрибутива NOTICE обязателен**. При чистом SaaS без передачи кода обязательства формально не возникают (нет distribution), но [ИБ-ЗАКАЗЧИК] **опросник по открытому ПО от ИНК запросит перечень компонентов и лицензий в любом случае** — так что делать всё равно придётся.

Минимальный набор файлов, которых сейчас нет и которые нужно создать: - LICENSE — Apache-2.0 в корне репозитория (сейчас отсутствует, хотя лицензия заявлена). - NOTICE — атрибуции по Apache-2.0-компонентам + OpenCorpora. - THIRD_PARTY_LICENSES.md — полный

SBOM: компонент, версия, лицензия, ссылка, текст лицензии. - [РЕКОМЕНДАЦИЯ] Генерировать автоматически (pip-licenses, license-checker для pnpm) и обновлять в CI — иначе документ протухнет за месяц.

В.18. Проверка допущения по Natasha и OPF

Допущение брифа не подтвердилось. Разбираю оба случая, как и просили, но с поправкой на факт.

Факт: Natasha не удалена и является значением по умолчанию: - engine.py:499 — ner_backend: str = "natasha"; - engine.py:570-573 — elif ner_backend == "natasha": from .ner import NatashaDetector; - ner.py:36 — from natasha import NewsEmbedding, NewsNERTagger, Segmenter; - anonymize_document.py:58 — ner_backend = "gliner" if args.gliner else "natasha"; - detectors.py:1071 — from natasha import MorphVocab как fallback морфологии.

В requirements.txt строка natasha закомментирована — то есть пакет не устанавливается автоматически, и в продовой конфигурации (--ner remote) ветка не исполняется. Но код присутствует и вызывается при иной конфигурации запуска.

OPF (OpenAI Privacy Filter) в кодовой базе не найден. Считаю, что он действительно отсутствует.

Случай 1 — компонент удалён из сборки и из репозитория (справедливо для OPF). Лицензионные обязательства прекращаются полностью. Ни атрибции, ни NOTICE, ни упоминания в SBOM не требуется. Упрощение реальное: снимается вопрос об Apache-2.0-обязательствах OPF и о транзитивных зависимостях.

Случай 2 — код остался в репозитории, но не вызывается (справедливо для Natasha). [ЗАКОН] **Обязательства сохраняются.** Лицензии на ПО привязаны к воспроизведению и распространению, а не к исполнению. Если вы распространяете репозиторий или дистрибутив, содержащий импорты и интеграционный код Natasha, а тем более сами пакеты — вы обязаны исполнять MIT-условия Natasha и условия её транзитивных зависимостей (rumorphy2 — MIT, razdel, navec, slovnet, yargy — MIT, словари OpenCorpora — CC BY-SA). Более того: даже неисполняемая ветка означает, что при определённой конфигурации запуска компонент **используется**, а это уже не «мёртвый код», а поддерживаемая функциональность.

[РЕКОМЕНДАЦИЯ] Выберите одно из двух и сделайте это до вендорского аудита: - **Либо** удалите ветку Natasha полностью (ner.py, ветку в engine.py, флаги в CLI, fallback в detectors.py) — и тогда честно заявляйте, что компонента нет; - **Либо** оставьте и внесите Natasha и всю её транзитивную цепочку в THIRD_PARTY_LICENSES.md и NOTICE.

Промежуточное состояние — «вроде удалили, но код есть» — худший вариант: оно даёт и лицензионные обязательства, и недостоверное заявление в опроснике.

Дополнительно: удаление Natasha не устраняет зависимость от OpenCorpora, потому что detectors.py использует rumorphy3 напрямую как основной путь. Словари CC BY-SA остаются в стеке в любом случае.

В.19. Сводная таблица лицензий — см. раздел 4

БЛОК Г. СПЕЦИФИКА ЗАКАЗЧИКА (ИНК)

Г.20. КИИ: 187-ФЗ и что это значит для внешнего SaaS

[ЗАКОН] ФЗ от 26.07.2017 № 187-ФЗ относит к сферам функционирования субъектов КИИ в том числе **топливно-энергетический комплекс, горнодобывающую, химическую промышленность и энергетику**. Нефтегазовая компания уровня ИНК — субъект КИИ практически наверняка.

Категорирование. Правила — ПП РФ от 08.02.2018 № 127 (действующая редакция от 07.11.2025, с изменениями, внесёнными ПП № 1281 и № 1762 [ПРОВЕРИТЬ реквизиты]). Существенное изменение последней редакции: из методики **исключено выявление «критических процессов»** и привязка к ним систем; категорированию подлежат объекты, соответствующие типам из перечней типовых отраслевых объектов КИИ, утверждаемых Правительством (перечень типовых объектов — распоряжение № 360-р [ПРОВЕРИТЬ]). Категории значимости — первая (высшая), вторая, третья; либо объект признаётся незначимым.

Что это значит для внешнего SaaS — три уровня последствий:

1. **Если ваш сервис попадёт в контур значимого объекта КИИ** (обрабатывает документы, циркулирующие в ЗОКИИ, или интегрирован с системами ЗОКИИ) — на него распространяются требования приказа ФСТЭК России от 25.12.2017 № 239 к обеспечению безопасности значимых объектов. Это принципиально более тяжёлый режим, чем 152-ФЗ: контроль состава ПО, запрет неконтролируемых внешних подключений, обязательное подключение к ГосСОПКА.
2. **Требование российского ПО на значимых объектах.** [ЗАКОН] ФЗ от 07.04.2025 № 58-ФЗ [ПРОВЕРИТЬ реквизиты и точную формулировку]: с 1 сентября 2025 г. субъекты КИИ, владеющие значимыми объектами, обязаны прекратить использование иностранного ПО на этих объектах; с 1 января 2026 г. средства защиты информации должны быть российского происхождения. Базовый ориентир полного перехода значимых объектов на российское ПО — 1 января 2028 г. Требования к доверенным программно-аппаратным комплексам — ПП РФ от 14.11.2023 № 1912.

Прямое следствие для вас: SaaS, вызывающий внешнюю LLM через интернет, **не может быть использован в контуре значимого объекта КИИ**. Это не вопрос переговоров — это архитектурный запрет.

3. **Если сервис используется вне ЗОКИИ** (например, юридическим департаментом для подготовки документов к передаче контрагентам) — требования 187-ФЗ формально не применяются, действует только 152-ФЗ. **Это ваш реалистичный сценарий входа в ИНК.**

[РЕКОМЕНДАЦИЯ] Стройте коммерческое предложение исходя из того, что ИНК потребует **изолированную поставку на своей инфраструктуре** (on-prem, локальный инференс, без исходящих соединений). Начните с ограниченного пилота вне ЗОКИИ на не-критичных документах, зафиксировав границы в договоре, и параллельно разрабатывайте on-prem-редакцию. SaaS-модель с внешним шлюзом для ИНК — тупик, и лучше это понять до, а не после переговоров.

[ИБ-ЗАКАЗЧИК] Отдельно готовьтесь к вопросу о **подключении к ГосСОПКА** и о порядке информирования НКЦКИ об инцидентах: субъект КИИ обязан это делать, и он потребует от вас совместимого процесса с конкретными сроками уведомления (обычно жёстче законных 24 часов по ст. 21 152-ФЗ).

Г.21. Реестр российского ПО

[ЗАКОН] Правила формирования и ведения единого реестра российских программ — ПП РФ от 16.11.2015 № 1236 (действующая редакция от 09.12.2025; основная часть изменений вступила

в силу **1 марта 2026 г.**, требования совместимости по классам ПО вводятся в четыре этапа). Существенное изменение: вместо критерия владения введён **критерий контроля** — не менее 50% голосов в компании-правообладателе должны принадлежать гражданам РФ, Российской Федерации, субъектам РФ или муниципальным образованиям. [ПРОВЕРИТЬ: сообщения о новом ПП № 1937, 2026 г., требуют сверки — возможна замена или существенная переработка правил.]

Нужен ли реестр для продажи ИНК. [ЗАКОН] Формально — **нет**. Ограничения на закупку иностранного ПО (ПП РФ от 16.11.2015 № 1236 в части запрета) распространяются на государственные и муниципальные закупки по 44-ФЗ. ИНК — коммерческая организация; если закупка идёт по 223-ФЗ, требование российского происхождения может быть установлено **положением о закупке самого заказчика**, и у крупных компаний с госучастием оно, как правило, установлено.

[ПРАКТИКА] Реальная причина, по которой реестр вам понадобится: (а) если ИНК признает объект значимым — требование российского ПО становится императивным (см. Г.20); (б) реестровая запись — сильный маркетинговый и переговорный аргумент; (в) льгота по НДС при реализации прав на ПО из реестра (пп. 26 п. 2 ст. 149 НК РФ).

Влияет ли использование Gemma и зарубежных моделей на возможность включения. [СПОРНО], и это ключевой вопрос для вас.

- Формальный критерий реестра — правообладание и контроль над **программой**, отсутствие ограничений со стороны иностранных лиц на её использование и распространение, доля выплат иностранным правообладателям не более 30% выручки.
- Толкование 1 (мягкое): Gemma 4 под Apache-2.0 — свободная лицензия без ограничений; включение в состав дистрибутива компонентов под свободными лицензиями реестру не препятствует, что подтверждается наличием в реестре множества продуктов на открытых компонентах.
- Толкование 2 (консервативное): если модель **вызывается через зарубежный сервис** или загружается с зарубежного хаба (Hugging Face) во время работы, экспертиза Минцифры может усмотреть зависимость от иностранного сервиса, а не от свободного компонента. Плюс новые требования 2026 г. к решениям с генеративным ИИ ужесточают планку (в частности, для ПАК под генеративные модели введены требования по инфраструктуре).

[РЕКОМЕНДАЦИЯ] Для реестровой перспективы: (1) обеспечить работу **без обращений к зарубежным сервисам во время исполнения** — веса моделей поставлять в дистрибутиве; (2) заменить `oui.interfonica.cloud` на локальный инференс либо на российский сервис-провайдер с российским договором; (3) быть готовым обосновать, что Gemma/GLiNER — свободно лицензируемые компоненты, а не иностранный сервис; (4) [ПРОВЕРИТЬ] актуальные требования по классу ПО и требования к ИИ-решениям в редакции, действующей на дату подачи — они менялись дважды за последний год.

Г.22. Коммерческая тайна (98-ФЗ)

Это отдельный и независимый от ПДн режим, и он для ИНК будет не менее важен, чем персональные данные. Содержимое загружаемых документов — договоры, приказы, техническая документация, ценообразование, сведения о запасах и добыче — это коммерческая тайна ИНК, а часть сведений в нефтегазовой отрасли может относиться и к государственной тайне (тогда работа с ними для вас закрыта в принципе — отдельно проверьте это ограничение с заказчиком).

[ЗАКОН] ФЗ от 29.07.2004 № 98-ФЗ, ст. 10: режим коммерческой тайны считается установленным только при принятии **всех** мер: (1) определение перечня сведений, составляющих КТ; (2) ограничение доступа путём установления порядка обращения и контроля за его соблюдением; (3) учёт лиц, получивших доступ; (4) регулирование отношений по

использованию КТ работниками (на основании трудовых договоров) и контрагентами (на основании гражданско-правовых договоров); (5) нанесение грифа «Коммерческая тайна» с указанием обладателя.

Ключевое практическое следствие, которое часто упускают: ст. 11 98-ФЗ — убытки **не возмещаются**, если разглашение произошло вследствие несоблюдения обладателем мер по охране конфиденциальности. То есть если у вас самих режим КТ не введён, вы (а) не сможете защитить собственные разработки и (б) не сможете принять на себя обязательства по чужой КТ в форме, которая устроит юристов ИНК.

Требования к NDA и к обращению с документами:

- **Двустороннее NDA** до передачи любых материалов — включая этап пилота и демонстрации.
- В NDA: определение конфиденциальной информации, срок действия обязательств (для КТ — обычно 3–5 лет после прекращения договора, иногда бессрочно), порядок передачи и возврата/уничтожения, круг допущенных лиц, обязанность вести учёт, **право заказчика на аудит**, ответственность (для корпоративных NDA типична фиксированная неустойка).
- **Запрет на использование содержимого документов для обучения моделей** — отдельным жирным пунктом. Он же должен быть транслирован в договор со шлюзом. Это первый вопрос, который задаст юрист ИНК про ИИ-сервис.
- Обращение с документами: приём только по защищённому каналу, обработка в изолированном контуре, немедленное удаление после обработки, журналирование доступа, персональные обязательства работников.
- [РЕКОМЕНДАЦИЯ] Для ИНК — предусмотреть режим, при котором документы **не покидают их периметр** вообще. Это единственный способ снять большую часть вопросов по КТ разом.

Ваши внутренние действия: приказ о введении режима КТ, перечень сведений, положение о КТ, ознакомление работников под подпись, гриф на документах, журнал учёта доступа. Это две недели работы и предпосылка для любого серьёзного разговора.

Г.23. Вендорский ИБ-опросник ИНК: что вы не сможете закрыть сейчас

[ИБ-ЗАКАЗЧИК] Типовой опросник крупного нефтегазового заказчика — 100–300 пунктов. Ниже — те, где у вас сейчас нет ответа, и честная оценка.

Блокирующие (без них диалог не начнётся):

Пункт опросника	Ваше состояние	Оценка
Уведомление в РКН / выписка из реестра операторов	Отсутствует	Закрывается за 2 недели
Политика обработки ПДн (опубликованная)	Отсутствует	1 неделя
Приказ о назначении ответственного за организацию обработки ПДн	Отсутствует	1 день
Модель угроз безопасности ПДн	Отсутствует	3–4 недели
Акт определения уровня защищённости	Отсутствует	1 неделя после модели угроз

Пункт опросника	Ваше состояние	Оценка
Договор поручения обработки с субобработчиками (шлюз, хостер)	Отсутствует	Зависит от контрагентов, 2–6 недель
Перечень обрабатываемых ПДн	Отсутствует	1 неделя
Регламент реагирования на инциденты (24/72 ч по ст. 21)	Отсутствует	1–2 недели
Аутентификация на входном контуре сервиса	Отсутствует	1–2 дня разработки
Подтверждение размещения данных в РФ	Частично (переход в процессе)	2 недели

Закрываемые с оговорками:

Пункт	Состояние	Что писать
Аттестация ИСПДн / оценка эффективности мер	Нет	«Планируется к <дата>», приложить план
Результаты пентеста / анализа уязвимостей	Нет	Заказать внешний пентест — 2–4 недели, 150–400 тыс. ₽
SDLC, статический анализ, контроль зависимостей	Частично (есть тесты, <code>tests/</code> , <code>test_contract.py</code>)	Описать фактический процесс, добавить SCA в CI
Резервное копирование и восстановление	Нет персистентного хранилища	Это преимущество — так и опишите
Сертификация ISO 27001 / ГОСТ Р 57580	Нет	Честно «нет», указать компенсирующие меры
Страхование киберрисков	Нет	Рассмотреть: сильно помогает в переговорах об ответственности
Подключение к ГосСОПКА	Нет	Обязательно, если попадёте в контур КИИ
Перечень открытого ПО и лицензий (SBOM)	Нет	1 неделя, генерируется автоматически
Порядок уничтожения ПДн и подтверждения	Не формализован	1 неделя

Пункт	Состояние	Что писать
Организационная зрелость: штат ИБ, обучение	Скорее всего нет	Наиболее слабое место. Честно описать компенсирующие меры

Пункты, которые вы не закроее в принципе без изменения архитектуры:

- «Данные не передаются третьим лицам за пределы контура заказчика» — **не соответствует** при использовании внешнего LLM-шлюза.
- «ПО не имеет исходящих соединений в интернет» — **не соответствует**.
- «Все компоненты из реестра российского ПО» — **не соответствует**.
- «Криптографическая защита каналов сертифицированными СКЗИ ГОСТ» — **не соответствует**.

[РЕКОМЕНДАЦИЯ] Не пытайтесь пройти опросник в SaaS-конфигурации. Идите с предложением on-prem/изолированной поставки, где четыре последних пункта снимаются архитектурой, а не объяснениями.

БЛОК Д. ОТВЕТСТВЕННОСТЬ

Д.24. Административная и уголовная ответственность

Ст. 13.11 КоАП РФ в редакции ФЗ от 30.11.2024 № 420-ФЗ, вступившей в силу 30 мая 2025 г. Ниже — таблица размеров для юридических лиц. Источник вторичный (правовые агрегаторы), поэтому **весь блок помечен [ПРОВЕРИТЬ]** и подлежит сверке с текстом КоАП на consultant.ru перед использованием в переговорах или договоре.

Состав	Часть	Штраф юрлицу [ПРОВЕРИТЬ]
Обработка в непредусмотренных случаях либо несовместимо с целями сбора	ч. 1	150 000 – 300 000 Р
Обработка без согласия в письменной форме	ч. 2	300 000 – 700 000 Р
Отсутствие политики обработки ПДн	ч. 3	30 000 – 60 000 Р
Непредоставление информации субъекту	ч. 4	40 000 – 80 000 Р
Невыполнение требования об уточнении/удалении	ч. 5	50 000 – 90 000 Р
Необеспечение сохранности на материальных носителях	ч. 6	50 000 – 100 000 Р
Нарушение локализации (серверы не в РФ)	ч. 8	1 000 000 – 6 000 000 Р
Повторное нарушение локализации	ч. 9	6 000 000 – 18 000 000 Р
Неподача уведомления о начале обработки	ч. 10	100 000 – 300 000 Р

Состав	Часть	Штраф юрлицу [ПРОВЕРИТЬ]
Неуведомление РКН об инциденте	ч. 11	1 000 000 – 3 000 000 Р
Утечка: 1 000 – 10 000 субъектов	ч. 12	3 000 000 – 5 000 000 Р
Утечка: 10 000 – 100 000 субъектов	ч. 13	5 000 000 – 10 000 000 Р
Утечка: свыше 100 000 субъектов	ч. 14	10 000 000 – 15 000 000 Р
Повторная утечка	ч. 15	оборотный: 1–3% выручки, не менее 20 млн и не более 500 млн Р
Утечка специальных категорий ПДн	ч. 16	10 000 000 – 15 000 000 Р
Утечка биометрических ПДн	ч. 17	15 000 000 – 20 000 000 Р
Повторная утечка спец. категорий или биометрии	ч. 18	оборотный: 1–3% выручки, 25–500 млн Р

Три вывода, которые важнее самих цифр:

1. **Составы суммируются.** Отсутствие политики + отсутствие уведомления + обработка без основания — это три самостоятельных постановления в одной проверке.
2. **Оборотный штраф привязан к выручке нарушителя.** Для вас как небольшой компании нижняя граница 20 млн Р при повторной утечке — это, вероятно, конец бизнеса. Для ИНК — это цифра, из-за которой их юристы будут требовать от вас неограниченной ответственности. Отсюда критическая важность п. об ограничении ответственности.
3. [ПРАКТИКА] РКН, как правило, **не штрафует за сам факт утечки**, если оператор своевременно уведомил (24 ч — первичное, 72 ч — по результатам внутреннего расследования, ст. 21 152-ФЗ) и документально подтвердил принятые меры. Ответственность наступает за **несвоевременное уведомление или сокрытие**. Практический вывод: регламент реагирования на инциденты — не бумага для галочки, а инструмент, снижающий санкцию на порядок.

Процессуальное изменение. [ПРОВЕРИТЬ] По сообщениям правовых источников, ФЗ № 508-ФЗ (декабрь 2025 г.) с 28.12.2025 вернул рассмотрение дел по ст. 13.11 КоАП в юрисдикцию мировых судей. Практическое значение: срок давности при рассмотрении судьёй — 90 календарных дней по общему правилу ст. 4.5 КоАП; для отдельных категорий установлен годичный срок. **Точный срок давности применительно к ч. 8 ст. 13.11 нужно уточнить — от него напрямую зависит, исчерпан ли риск по эпизоду Vercel fra1.**

Ст. 272.1 УК РФ (незаконное использование и (или) передача, сбор и (или) хранение компьютерной информации, содержащей персональные данные; введена ФЗ от 30.11.2024, действует в редакции от 26.07.2026 [ПРОВЕРИТЬ номер вводящего закона]):

- **Ч. 1:** штраф до 300 000 Р или в размере заработной платы за период до 1 года, либо принудительные работы до 4 лет, либо лишение свободы на тот же срок.
- **Ч. 2** (в отношении ПДн несовершеннолетних, специальных категорий и (или) биометрических ПДн): штраф до 700 000 Р или в размере заработной платы до 2 лет с лишением права занимать определённые должности до 2 лет или без такового, либо принудительные работы до 5 лет, либо лишение свободы на тот же срок.

[РЕКОМЕНДАЦИЯ] Уголовный риск для вас реализуется прежде всего через **умышленную передачу** ПДн лицу, не имеющему на них права. Передача на внешний шлюз без оформленного поручения теоретически подпадает под объективную сторону ч. 1 — но требует установления умысла на незаконность. Риск невысокий, однако наличие оформленного договора поручения снимает его полностью, и это ещё один довод в пользу срочности п. А.1.

Ответственность обработчика перед оператором и регресс. [ЗАКОН] Ч. 5 ст. 6 152-ФЗ: перед субъектом отвечает оператор; обработчик отвечает перед оператором. Механика: субъект → иск к ИНК (компенсация морального вреда, ст. 24 152-ФЗ; практика по искам о моральном вреде за утечки в 2025–2026 гг. активизировалась) + штраф РКН на ИНК → **регресс ИНК к вам на всю сумму, если договором не ограничено**. Отсюда: если в договоре не будет лимита ответственности, вы принимаете на себя риск оборотного штрафа компании с выручкой в десятки миллионов рублей.

Санкции именно за локализацию и трансграничную передачу — отдельно: - Нарушение локализации — ч. 8 ст. 13.11 КоАП: 1–6 млн ₽; повтор (ч. 9): 6–18 млн ₽. - Трансграничная передача без уведомления по ч. 3 ст. 12 152-ФЗ: специального состава в ст. 13.11 нет; квалифицируется по ч. 1 ст. 13.11 (обработка в непредусмотренных законом случаях) и влечёт **предписание РКН, а также решение о запрете или ограничении трансграничной передачи** (ч. 8 и 12 ст. 12 в редакции ФЗ от 26.07.2026 № 265-ФЗ). Для SaaS-бизнеса запрет передачи опаснее штрафа: он останавливает работу сервиса. - [ПРАКТИКА] РКН вправе инициировать через суд ограничение доступа к ресурсу при систематических нарушениях, и по нарушениям локализации такие прецеденты есть.

4. Сводная таблица лицензий

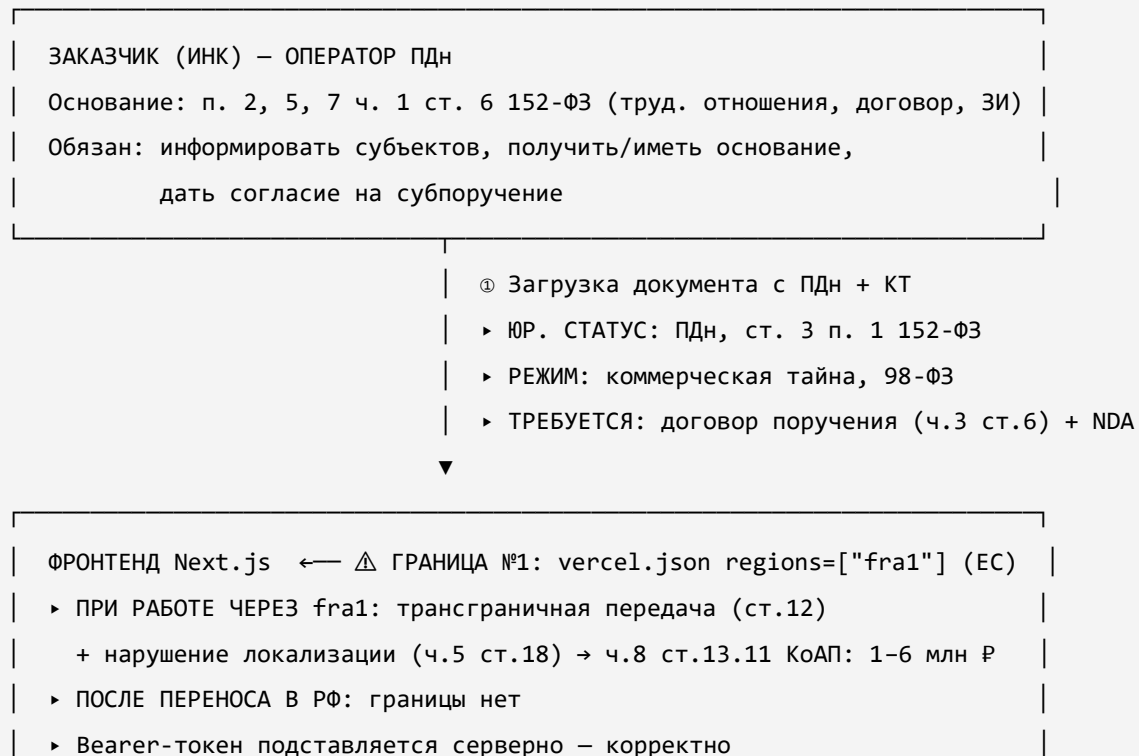
Компонент	Лицензия	Комм. использование	Обязательства	Риск
Gemma 4 (gemma4:12b, google/gemma-4-12b-qat, «Selectel Gemma 4 31B»)	Apache-2.0 (Gemma ToU на Gemma 4 не распространяется)	Разрешено без ограничений	При распространении — §4(a)–(d): копия лицензии, пометка изменений, сохранение уведомлений, NOTICE. При вызове по API — не возникают	Низкий
Gemma 1–3, 3n, PaliGemma, ShieldGemma, CodeGemma (если шлюз отдаёт их)	Gemma Terms of Use (ред. 01.04.2026)	Разрешено, в т.ч. hosted service	П. 3.1(1): перенести ограничения п. 3.2 как исполнимое условие в вашу оферту ; п. 3.1(2): предоставить копию ToU; соблюдать Prohibited Use Policy. NOTICE для hosted service не требуется	Средний — требует правки оферты
GLiNER knowledgator/gliner-relex-multi-v1.0	Apache-2.0 (подтверждено карточкой модели)	Разрешено	§4(a)–(d) при распространении весов	Низкий
GLiNER urchade/gliner_multi-v2.1 (альтернатива)	Apache-2.0	Разрешено	§4(a)–(d)	Низкий

Компонент	Лицензия	Комм. использование	Обязательства	Риск
Базовый энкодер GLiNER-чекпойнта	[ПРОВЕРИТЬ] — обычно MIT (mDeBERTa)	Зависит	Наследуются	Требует проверки
gliner (библиотека)	Apache-2.0	Разрешено	§4(a)–(d)	Низкий
Словари OpenCorpora через pymorphy3-dicts-ru	CC BY-SA (версию [ПРОВЕРИТЬ]); код pymorphy3 — MIT	Разрешено	Атрибуция обязательна. ShareAlike — только на адаптации самих словарей. При поставке дистрибутива со словарями — приложить текст лицензии	Средний. Copyleft на ваш код не распространяется
pymorphy3 / pymorphy2	MIT	Разрешено	Уведомление об авторских правах	Низкий
Natasha (в коде присутствует, дефолтный бэкэнд)	MIT; транзитивно razdel, navec, slovnet, yargy — MIT; словари — CC BY-SA	Разрешено	Уведомление; при распространении — вся транзитивная цепочка в NOTICE	Средний — из-за расхождения «считается удалённой / фактически есть»
transformers	Apache-2.0	Разрешено	§4(a)–(d), NOTICE	Низкий
huggingface-hub	Apache-2.0	Разрешено	§4(a)–(d)	Низкий; но сетевое обращение к HF Hub — блокер для изолированного контура
torch	BSD-3-Clause; CUDA-компоненты — отдельные условия NVIDIA	Разрешено	Уведомление; для CUDA-сборок при распространении образа — [ПРОВЕРИТЬ] условия NVIDIA	Низкий / средний при поставке образа
python-docx	MIT	Разрешено	Уведомление	Низкий
openpyxl	MIT	Разрешено	Уведомление	Низкий
lxml	BSD-3-Clause (libxml2/libxslt — MIT)	Разрешено	Уведомление, запрет использования имён для продвижения	Низкий
xlrd	BSD-3-Clause	Разрешено	Уведомление	Низкий
olefile	BSD-2-Clause	Разрешено	Уведомление	Низкий

Компонент	Лицензия	Комм. использование	Обязательства	Риск
pypdf	BSD-3-Clause	Разрешено	Уведомление	Низкий
Next.js	MIT	Разрешено	Уведомление	Низкий
React / React-DOM	MIT	Разрешено	Уведомление	Низкий
jszip	Двойная: MIT или GPLv3	Разрешено по MIT	Явно зафиксировать выбор MIT в документации. Иначе риск толкования в пользу GPLv3	Средний — снимается одной строкой
Streamlit (опционально)	Apache-2.0	Разрешено	§4(a)–(d)	Низкий
Ваш код	Заявлен Apache-2.0, файл LICENSE в репозитории отсутствует	—	Создать LICENSE, NOTICE, THIRD_PARTY_LICENSES.md	Средний — расхождение заявленного и фактического

Все лицензии в таблице проверены по первоисточникам, кроме помеченных [ПРОВЕРИТЬ]; версии пакетов не зафиксированы в requirements.txt (нет pin), поэтому фактические лицензии должны быть подтверждены на конкретных установленных версиях.

5. Схема потоков данных с юридической разметкой



② Прокси на бэкэнд

PYTHON-БЭКЕНД 127.0.0.1:8010 (за nginx), сервер Интерфоники, РФ

- Вы = лицо, осуществляющее обработку по поручению (ч.3 ст.6)
- ИСПДн, требует: акт УЗ, модель угроз, меры ФСТЭК №21
- ⚠ НЕТ входной аутентификации; CORS: * → риск НСД (R9)
- ⚠ _JOBS в RAM: результат + mapping, TTL 600 с, ленивая очистка
- ⚠ logs/usage.jsonl: filename (ПДн!) + error (возможен текст) → R6

③ СЫРОЙ ТЕКСТ ДО МАСКИРОВАНИЯ

④ Тот же сырой текст

⚠⚠ ГРАНИЦА №2 – ГЛАВНАЯ ⚠⚠

LLM-ШЛЮЗ

oui.interfonica.cloud/v1

/chat/completions

▸ НОВЫЙ СУБЪЕКТ ОТВЕТСТВЕННОСТИ

▸ КВАЛИФИКАЦИЯ БЕЗ ДОГОВОРА:

передача 3-му лицу без

основания → ч.1 ст.13.11

▸ КВАЛИФИКАЦИЯ С ДОГОВОРОМ:

субпоручение (ч.3 ст.6) –

законно

▸ ЕСЛИ АПСТРИМ ВНЕ РФ:

трансграничная передача,

ст.12 → уведомление РКН

▸ Тарификация «Selectel Gemma 4»

⇒ вероятно РФ. ПОДТВЕРДИТЬ

⚠⚠ ГРАНИЦА №2b

GLiNER remote

oui.interfonica.cloud/gliner

/extract

▸ Те же требования

⑤ Спаны сущностей (Output; не Model Derivative по п.1.1(e) Gemma ToU)

МАСКИРОВАНИЕ (engine.py + mapping.py)

▸ ⚡ ТОЧКА СМЕНЫ ПРАВОВОГО СТАТУСА – но НЕПОЛНОЙ:

текст → псевдонимизированные ПДн (НЕ обезличенные по п.9 ст.3)

mapping → ключ деанонимизации, самостоятельные ПДн

▸ Приказ РКН №140 (с 01.09.2025): запрет совместного хранения

исходных и обезличенных, обязателен учёт операций

| © Ответ: {anonymized_text, mapping, spans, docx}

| ⚠ Документ И ключ идут ОДНИМ ответом



| ЗАКАЗЧИК получает: замаскированный документ + таблицу соответствий

| ▶ ОБА объекта = ПДн. «Обезличивания» не произошло

| ▶ Ответственность за хранение ключа → оператору (зафиксировать в дог.)

ДОПОЛНИТЕЛЬНЫЕ КОНТУРЫ, НЕ ОТРАЖЁННЫЕ В БРИФЕ (требуют инвентаризации):

- app.py:86 → <https://jh.interfonica.cloud/user/ts-.../proxy/8000> (JupyterHub)

⚠ Учебная/исследовательская среда как продовый путь – недопустимо

- loadtest.py → <https://anon.cpcore.ru> ⚠ Публичный домен: чей, что там, есть ли ПДн

Где именно данные пересекают границу: - **Граница 1** (устраняется/устранена): фронтенд Vercel fra1 → территория ЕС. Смена юрисдикции. - **Граница 2** (действующая, главная): бэкенд → LLM-шлюз и GLiNER-шлюз. Смена **субъекта ответственности**; смены юрисдикции нет, **если** подтвердится российское размещение. - **Граница 3** (потенциальная, не установлена): шлюз → его апстрим. **Это чёрный ящик, и до его вскрытия любой вывод о трансграничной передаче условен.**

Где меняется правовой статус: только в точке ⑤–⑥, и **не полностью** — из ПДн получают псевдонимизированные ПДн плюс ключ. Полная смена статуса на «обезличенные данные» произошла бы только при безвозвратном уничтожении маппинга, чего сервис не делает.

Где появляется новый субъект ответственности: в точке ③/④ (оператор шлюза) и, возможно, в точке за ним (апстрим шлюза, напр. Selectel). Каждый требует оформленного субпоручения и согласия оператора-заказчика.

6. Если предложат сотрудничество прямо сейчас: план 0–30 дней

6.1. Минимальный пакет «показать заказчику завтра»

Реалистично собирается за 3–5 рабочих дней. Это не соответствие — это доказательство того, что вы управляемый поставщик, а не любители.

1. **Приказ о назначении ответственного за организацию обработки ПДн** (ст. 22.1 152-ФЗ) — 1 страница, делается за час.
2. **Политика обработки персональных данных** (ч. 2 ст. 18.1) — опубликованная на сайте.
3. **Перечень обрабатываемых персональных данных** и целей обработки.
4. **Описание архитектуры и потоков данных** — честная схема из раздела 5, с явным указанием внешнего LLM-шлюза. Скрывать бессмысленно: на техническом созвоне это вскрыется за 5 минут, и тогда вопрос перейдёт из технической плоскости в плоскость добросовестности.
5. **Перечень открытого ПО и лицензий (SBOM)** — генерируется автоматически.
6. **Проект NDA** — двусторонний, с запретом использования содержимого для обучения моделей.

7. **Roadmap соответствия** с датами: модель угроз, акт УЗ, договоры поручения, пентест. Показывает управляемость.
8. **Метрики полноты детекции** с описанием методики и эталонного набора (eval_benchmark.py уже позволяет их получить).

6.2. Полный перечень внутренних документов с приоритетами

P0 — блокирующие, без них договор не подписывается (0–30 дней):

Документ	Основание	Структура
Политика обработки ПДн	ч. 2 ст. 18.1 152-ФЗ	Общие положения; правовые основания и цели; категории субъектов (вкл. лиц из документов заказчиков); категории ПДн; порядок и условия обработки; поручение обработки и перечень субобработчиков; трансграничная передача; сроки; порядок уничтожения; права субъектов и маршрутизация обращений; применяемые меры; ответственный
Приказ о назначении ответственного	ст. 22.1 152-ФЗ	Назначение; полномочия; подчинённость; порядок замещения
Перечень обрабатываемых ПДн	ч. 2 ст. 18.1	Категория субъектов → состав ПДн → цель → основание → срок хранения → место обработки → субобработчик
Уведомление в РКН	ст. 22	По форме РКН; обязательно блоки о поручении обработки и трансграничной передаче
Договор поручения обработки со шлюзом	ч. 3 ст. 6	Перечень ПДн; перечень операций; конфиденциальность; меры по ст. 19; запрет обучения на данных; запрет логирования содержимого ; срок хранения; уведомление о неправомерной передаче ≤24 ч; территория обработки; запрет дальнейшего субпоручения без согласия; право аудита; порядок уничтожения
Договор поручения обработки с хостером	ч. 3 ст. 6	Аналогично
Модель угроз безопасности ПДн	ст. 19; методика ФСТЭК 2021	Описание ИСПДн; границы; нарушители; актуальные угрозы (вкл. НСД к памяти, дампы, swar, канал до шлюза, доступ к логам); неактуальные с обоснованием; меры нейтрализации
Акт определения уровня защищённости	ПП РФ № 1119	Исходные данные; категория ПДн; тип угроз с обоснованием; количество субъектов; вывод об УЗ; подписи комиссии
Регламент реагирования на инциденты	ст. 21 152-ФЗ	Классификация; роли; уведомление РКН ≤24 ч, результаты расследования ≤72 ч ; уведомление оператора-заказчика; формы; журнал; порядок расследования
Порядок уничтожения ПДн	ст. 21	Основания; способы (вкл. RAM); сроки; акт; журнал; подтверждение для заказчика

Документ	Основание	Структура
Приказ о введении режима коммерческой тайны + перечень + положение	ст. 10, 11 98-ФЗ	Перечень сведений; порядок обращения; учёт лиц; обязательства работников; грифы
NDA (шаблон)	98-ФЗ, ГК	См. п. Г.22
Договор оказания услуг + соглашение о поручении обработки (шаблон для заказчика)	ГК, ч. 3 ст. 6	См. п. 6.4

Р1 — нужны для серьёзного заказчика (30–90 дней):

- Положение об обработке ПДн (внутренний регламент для работников).
- Инструкция администратора безопасности; инструкция пользователя.
- Журналы: учёта СЗИ, учёта носителей, доступа к ИСПДн, инцидентов, операций обезличивания (приказ РКН № 140).
- Акт оценки эффективности принятых мер (ч. 4 ст. 19 152-ФЗ) — не реже одного раза в 3 года.
- Оценка вреда субъектам ПДн (по методике РКН [ПРОВЕРИТЬ реквизиты приказа]).
- Обязательства работников о неразглашении; программа обучения и журнал инструктажей.
- Отчёт о внешнем тестировании на проникновение.
- LICENSE, NOTICE, THIRD_PARTY_LICENSES.md.
- План обеспечения непрерывности и восстановления.

Р2 — конкурентное преимущество (90+ дней):

- Аттестат соответствия ИСПДн или заключение по результатам оценки эффективности.
- Сертификация по ГОСТ Р ИСО/МЭК 27001.
- Включение в реестр российского ПО.
- Страхование киберрисков.
- Подключение к ГосСОПКА (если работа в контуре КИИ).

6.3. Что можно честно заявить сейчас, а что нельзя

Можно заявлять (это правда и проверяемо):

- «Обработка выполняется на серверах, расположенных на территории Российской Федерации» — **после** завершения переноса и получения подтверждающих документов.
- «Сервис не сохраняет исходные документы и таблицы соответствий в постоянном хранилище; данные обрабатываются в оперативной памяти и удаляются по завершении обработки» — при условии реализации детерминированного TTL и отключения дампов.
- «Все программные компоненты используются на условиях свободных лицензий, допускающих коммерческое использование» — после сверки SBOM.
- «Реализовано автоматизированное выявление и маскирование прямых идентификаторов персональных данных с измеренной полнотой не менее X% на эталонном наборе (методика и набор приложены)».
- «Токен доступа к внешним сервисам не передаётся в браузер клиента».
- «Модели ИИ используются на условиях лицензии Apache-2.0» — при подтверждении Gemma 4.

Заявлять нельзя (риск недостоверного заверения по ст. 431.2 ГК):

- **✗** «Сервис обезличивает персональные данные в соответствии с 152-ФЗ» — пока сервис обратим, это ложное утверждение (см. А.3).
- **✗** «Персональные данные не передаются третьим лицам» — они передаются на LLM-шлюз. **Это самое опасное из возможных заявлений:** его опровержение одним сетевым дампом разрушает доверие целиком.
- **✗** «Соответствуем требованиям 152-ФЗ» — без модели угроз, акта УЗ и договоров поручения это утверждение не подкреплено ничем.
- **✗** «Гарантируем выявление всех персональных данных» / любые «100%».
- **✗** «Данные не покидают периметр» — в текущей SaaS-архитектуре неверно.
- **✗** «Инфраструктура аттестована по 152-ФЗ» — аттестован (возможно) ЦОД провайдера, а не ваша ИСПДн. Это разные вещи, и аудитор различие знает.
- **✗** «Используем сертифицированные СЗИ» — до фактической закупки.
- **✗** Любое утверждение о `oui.interfonica.cloud`, не подтверждённое письменно самим оператором шлюза.

6.4. Формулировки для договора с ИНК

Ниже — рабочие заготовки. **Перед подписанием обязательно отдать практикующему юристу:** формулировки ограничения ответственности в отношении с корпорацией всегда правятся под конкретный договор.

Предмет (заменяет «обезличивание»):

«Исполнитель оказывает услуги по автоматизированному выявлению и маскированию (псевдонимизации) прямых идентификаторов персональных данных в документах Заказчика с формированием таблицы соответствий, обеспечивающей возможность обратного преобразования. Стороны признают, что результат обработки не является обезличенными персональными данными в значении пункта 9 статьи 3 Федерального закона от 27.07.2006 № 152-ФЗ и сохраняет статус персональных данных.»

Заверения Исполнителя (ограниченные и исполнимые):

«Исполнитель заверяет, что: (а) обработка персональных данных осуществляется на технических средствах, расположенных на территории Российской Федерации; (б) Исполнитель не использует содержание документов Заказчика для обучения моделей машинного обучения и обеспечил соответствующий запрет в договорах с привлекаемыми лицами; (в) полнота выявления персональных данных категорий, указанных в Приложении № __, составляет не менее % при измерении по методике, приведённой в Приложении № __; (г) Исполнитель уведомит Заказчика о любом факте неправомерной или случайной передачи персональных данных в течение 12 (двенадцати) часов с момента выявления.»

Заверения Заказчика (перекладывают то, что не ваше):

«Заказчик заверяет, что располагает надлежащим правовым основанием обработки передаваемых Исполнителю персональных данных, исполнил обязанности по информированию субъектов персональных данных, включая сведения о поручении обработки третьим лицам, и даёт согласие на привлечение Исполнителем лиц, указанных в Приложении № __ (перечень субобработчиков), для целей исполнения настоящего Договора.»

Ограничение ответственности (ключевой пункт):

«Совокупная ответственность Исполнителя по настоящему Договору, включая возмещение убытков и уплату неустоек, ограничивается суммой вознаграждения, фактически уплаченного Заказчиком за 12 (двенадцать) месяцев, предшествующих событию, послужившему основанием требования. Исполнитель не несёт ответственности за упущенную выгоду, а также за административные штрафы, наложенные на Заказчика, за исключением случаев, когда они явились прямым следствием умышленных действий Исполнителя или его грубой неосторожности.»

Заказчик уровня ИНК будет настаивать на исключении административных штрафов из-под лимита. [РЕКОМЕНДАЦИЯ] Разумный компромисс: отдельный, повышенный, **но конечный** суб-лимит по штрафам за утечку (например, трёхкратное годовое вознаграждение), плюс обязательное условие о немедленном уведомлении и совместной защите. Неограниченная ответственность за штрафы — см. красные флаги.

Ограничение по составу данных (защищает УЗ-3):

«Заказчик обязуется не передавать Исполнителю документы, содержащие специальные категории персональных данных (статья 10 Федерального закона № 152-ФЗ), биометрические персональные данные (статья 11), а также сведения, составляющие государственную тайну. Исполнитель не несёт ответственности за последствия передачи таких сведений в нарушение настоящего пункта.»

Верификация результата:

«Заказчик обязуется до передачи результата обработки третьим лицам или его публикации осуществить проверку результата уполномоченным работником. Обязательство Исполнителя считается исполненным надлежащим образом при достижении показателей полноты, указанных в Приложении № __.»

6.5. Красные флаги — условия, на которые нельзя соглашаться без доработки продукта

1. **Неограниченная ответственность за утечку.** При оборотном штрафе 1–3% выручки ИНК это обязательство, которое вы физически не сможете исполнить. Подписывать нельзя ни при каких обстоятельствах.
2. **Заверение об «обезличивании» в терминах 152-ФЗ.** Заведомо недостоверное заверение — прямая дорога к ст. 431.2 ГК.
3. **Гарантия полноты 100% или «выявления всех ПДн».**
4. **Обязательство соответствия требованиям к значимым объектам КИИ** без предварительного категорирования и без on-prem-редакции. Приказ ФСТЭК № 239 в текущей архитектуре не исполним.
5. **Согласие на обработку специальных категорий ПДн и биометрии** без пересмотра уровня защищённости на УЗ-2 и закупки сертифицированных СЗИ.
6. **Обязательство не привлекать третьих лиц** — вы физически привлекаете LLM-шлюз. Подписав, вы окажетесь в нарушении с первого дня.
7. **Право заказчика на односторонний аудит вашей инфраструктуры без ограничений** — по крайней мере до того, как инфраструктура приведена в порядок. Ограничьте: разумное уведомление, рабочее время, NDA, не чаще раза в год.
8. **Обязательство хранить документы заказчика** — противоречит вашей главной защитной позиции («ничего не храним») и создаёт полноценную ИСПДн с хранением.
9. **Штрафные санкции, не привязанные к фактическому ущербу**, в размере, превышающем годовое вознаграждение.
10. **Обязательство подключения к ГосСОПКА и передачи данных в НКЦКИ** без понимания, что это технически и организационно означает для вас.
11. **Согласие на использование данных заказчика для улучшения сервиса** — даже в мягкой формулировке. Для ИНК это будет означать разглашение коммерческой тайны.
12. **Applicable law / арбитраж на невыгодных условиях** — мелочь по сравнению с остальным, но проверьте.

6.6. Изменения в архитектуре: обязательные до подписания и откладываемые КРИТИЧНО — сделать до подписания договора (без этого подписывать нельзя):

#	Изменение	Почему до подписания	Трудоёмкость
1	Оформить договор поручения с оператором LLM/GLiNER-шлюза (юридическое, но блокирующее)	Без него каждый вызов — нарушение	1–4 недели (зависит от контрагента)
2	Аутентификация на входном контуре Python-сервера	Открытый бэкэнд + CORS * = отказ ИБ-аудита	1–2 дня
3	Access-Control-Allow-Origin из белого списка	То же	1 час
4	Привязка job_id к аутентифицированному субъекту + криптостойкий идентификатор	IDOR: доступ к чужим документам	1 день
5	Удалить vercel.json с fra1, вывести EC-контур	Длжащееся нарушение локализации	1 час + документирование
6	Санитизация logs/usage.json1: хеш имени файла, error без тела ответа	Неучтённая ИСПДн	2–4 часа
7	Детерминированный TTL заданий (фоновый сборщик вместо ленивой очистки) + отключение core dumps + mlock	Иначе декларируемый срок хранения недостоверен	2–3 дня
8	Инвентаризация и вывод из эксплуатации лишних контуров (jh.interfonica.cloud, anon.cpcore.ru)	Неучтённые точки обработки	1–2 дня
9	Зафиксировать письменно, какую модель отдаёт шлюз; устранить разноречивость дефолтов в коде	Лицензионная определённость + достоверность заявлений	1 день
10	LICENSE, NOTICE, THIRD_PARTY_LICENSES.md	Опросник по открытому ПО	1 день

ВАЖНО — в течение 90 дней после подписания, зафиксировать в roadmap договора:

#	Изменение	Эффект
11	Stateless-режим: маппинг не хранится на сервере вовсе	Снимает большую часть возражений по ключу деанонимизации
12	Предварительное детерминированное маскирование до отправки на LLM (СНИЛС, ИНН, паспорт, карты, телефоны — detectors.py уже умеет)	Радикально снижает объём ПДн, пересекающих границу №2
13	Разделение каналов доставки документа и маппинга	Приказ РКН № 140: запрет совместного хранения

#	Изменение	Эффект
14	Режим «безвозвратного обезличивания» без формирования маппинга	Единственный режим, где термин «обезличивание» юридически корректен
15	Журнал операций обезличивания	Приказ РКН № 140: обязателен учёт действий
16	Rate limiting, защита от архивных бомб и вредоносных документов	Типовой пункт ИБ-опросника
17	Локальные веса моделей без обращений к Hugging Face Hub во время работы	Предпосылка для изолированного контура и реестра ПО

МОЖНО ОТЛОЖИТЬ (90+ дней, но заявить в roadmap):

#	Изменение	Когда становится обязательным
18	On-prem / изолированная поставка с локальным инференсом	Обязательно, если ИНК потребует работу в контуре ЗОКИИ. Планировать сразу — это стратегическая развилка продукта
19	ГОСТ-VPN / сертифицированные СКЗИ на внешних каналах	При УЗ-2 или по требованию ИБ заказчика
20	Аттестация ИСПДн	При работе с ГИС или по требованию заказчика
21	Включение в реестр российского ПО	При закупке с требованием российского происхождения
22	Подключение к ГосСОПКА	При работе в контуре КИИ
23	Сертификация ISO 27001 / ГОСТ Р 57580	Конкурентное преимущество

7. План действий 0–30 / 30–90 / 90+ дней

0–30 дней

Юридические задачи

Приоритет	Задача	Результат
P0	Установить фактические обстоятельства по oui.interfonica.cloud: юрлицо, площадка, апстрим, логирование, обучение	Письмо-подтверждение от оператора шлюза

Приоритет	Задача	Результат
P0	Заключить договор поручения обработки с оператором шлюза	Подписанный договор
P0	Заключить/дополнить договор поручения с хостером (Интерфоника), собрать пакет из п. Б.12	Договор + 9 документов
P0	Приказ о назначении ответственного за организацию обработки ПДн	Приказ
P0	Политика обработки ПДн + публикация	Опубликованный документ
P0	Перечень обрабатываемых ПДн	Документ
P0	Уведомление в РКН по ст. 22	Запись в реестре операторов
P0	Документирование эпизода Vercel fra1: период, характер данных, акт переноса, акт уничтожения	Досье
P0	Решение по ретроспективному уведомлению о трансграничной передаче	Служебная записка с обоснованием
P0	Ревизия всех публичных материалов: убрать «обезличивание»	Обновлённые сайт, презентация, README
P1	Введение режима коммерческой тайны	Приказ, перечень, положение, грифы
P1	Шаблоны NDA, договора услуг, соглашения о поручении	3 шаблона
P1	Регламент реагирования на инциденты (24/72 ч)	Регламент + формы

Инженерные задачи

Приоритет	Задача
P0	Аутентификация входного контура Python-сервера
P0	CORS: белый список вместо *
P0	Привязка job_id к субъекту, криптостойкий идентификатор
P0	Удалить web/vercel.json (fra1), вывести EC-деплой
P0	Санитизация usage.jsonl: хеш filename, error без тела ответа

Приоритет	Задача
P0	Детерминированный TTL, отключение core dumps, mlock для маппинга
P0	Инвентаризация и отключение <code>jh.interfonica.cloud / anon.cpcore.ru</code> из продового пути
P0	Единый дефолт модели во всём коде; зафиксировать в документации
P1	<code>LICENSE, NOTICE, THIRD_PARTY_LICENSES.md</code> + генерация SBOM в CI
P1	Прогон <code>eval_benchmark.py</code> , оформление протокола измерения полноты
P1	Решение по Natasha: удалить полностью либо внести в SBOM
P1	Pin версий в <code>requirements.txt</code> (сейчас версии не зафиксированы — SBOM недостоверен)

30–90 дней

Юридические

- Модель угроз безопасности ПДн по методике ФСТЭК.
- Акт определения уровня защищённости ИСПДн.
- Оценка вреда субъектам ПДн.
- Порядок уничтожения ПДн + журналы.
- Положение об обработке ПДн, инструкции администратора и пользователя.
- Обязательства работников о неразглашении, программа обучения, журнал инструктажей.
- Согласование с ИНК перечня субобработчиков и получение письменного согласия на субпоручение.
- Проработка позиции по КИИ: запрос к ИНК о категории объекта, в контуре которого будет использоваться сервис.

Инженерные

- Stateless-режим маппинга.
- Предварительное детерминированное маскирование до вызова LLM.
- Разделение каналов доставки документа и маппинга.
- Журнал операций обезличивания (приказ РКН № 140).
- Rate limiting, защита от вредоносных и архивных документов.
- Локальные веса моделей, отказ от обращений к HF Hub в рантайме.
- Внешний пентест и устранение находок.
- Реализация мер приказа ФСТЭК № 21 в объёме определённого УЗ.

90+ дней

Юридические

- Акт оценки эффективности принятых мер (ч. 4 ст. 19 152-ФЗ).
- Проработка включения в реестр российского ПО.
- Оценка целесообразности аттестации ИСПДн.

- Страхование киберрисков.
- Оценка применимости ФЗ от 26.07.2026 № 243-ФЗ «О поддержке развития технологий искусственного интеллекта» (основные нормы — с 01.03.2027; вводит требование обработки и хранения данных в российских ЦОД для регулируемых моделей — **отдельно отследить, попадает ли ваш сценарий использования под регулирование**).

Инженерные

- On-prem / изолированная редакция с локальным инференсом.
- ГОСТ-криптография на внешних каналах при необходимости.
- Подключение к ГосСОПКА при работе в контуре КИИ.
- Подготовка к сертификации по ГОСТ Р ИСО/МЭК 27001.

8. Пакет документов со структурой каждого

Ниже — только те документы, структура которых не раскрыта выше в п. 6.2. Для остальных структура приведена там.

Модель угроз безопасности персональных данных 1. Общие положения, нормативные основания, методика ФСТЭК. 2. Описание ИСПДн: назначение, состав, программные и аппаратные компоненты, интерфейсы, схема потоков (использовать раздел 5). 3. Границы контролируемой зоны; описание внешних взаимодействий (LLM-шлюз, GLiNER-шлюз, хостер). 4. Категории обрабатываемых ПДн и субъектов. 5. Модель нарушителя: типы, потенциал, мотивация (внешний нарушитель через интернет; недобросовестный работник; работник оператора шлюза; работник хостера). 6. Перечень актуальных угроз с обоснованием: НСД к памяти процесса; утечка через core dumps и swar; компрометация канала до шлюза; компрометация на стороне шлюза; НСД к usage.json1; IDOR по job_id; загрузка вредоносных документов; отказ в обслуживании. 7. Перечень угроз, признанных неактуальными, с обоснованием (в т.ч. угрозы СУБД и резервных копий — со ссылкой на отсутствие персистентного хранилища). 8. Меры нейтрализации по каждой актуальной угрозе. 9. Остаточные риски и решение об их принятии.

Акт определения уровня защищённости 1. Состав комиссии, дата. 2. Исходные данные: наименование ИСПДн, категории ПДн, количество субъектов. 3. Определение типа актуальных угроз с обоснованием (со ссылкой на модель угроз). 4. Определение уровня защищённости по ПП РФ № 1119 с расчётом. 5. Вывод: требуемый УЗ и перечень применимых мер приказа ФСТЭК № 21. 6. Подписи.

Регламент реагирования на инциденты 1. Термины; классификация инцидентов (неправомерная передача; НСД; утечка; компрометация учётных данных; инцидент на стороне субобработчика). 2. Роли и контакты; порядок эскалации; круглосуточная доступность ответственного. 3. Порядок обнаружения и первичной фиксации. 4. **Сроки: уведомление РКН — 24 часа с момента выявления; результаты внутреннего расследования — 72 часа. Уведомление оператора-заказчика — не позднее 12 часов (договорный срок, жёстче законного).** 5. Формы уведомлений (шаблоны). 6. Порядок внутреннего расследования, сбора и сохранения доказательств. 7. Взаимодействие с субобработчиками; обязанность шлюза и хостера уведомить вас. 8. Журнал инцидентов; порядок анализа и корректирующих действий.

Соглашение о поручении обработки ПДн (с ИНК) — приложение к договору 1. Предмет: поручение обработки, цели. 2. Перечень персональных данных (по категориям). 3. Перечень действий (операций) с ПДн — исчерпывающий. 4. Территория обработки. 5. Обязанность соблюдать конфиденциальность и требования ст. 18.1, 19 152-ФЗ. 6. **Перечень привлекаемых лиц (субобработчиков) и согласие оператора на их привлечение.** 7. **Обязанность уведомления оператора о фактах неправомерной или случайной передачи — с указанием срока.** 8. Запрет использования данных в собственных целях, включая обучение моделей. 9.

Порядок и сроки уничтожения ПДн, форма подтверждения. 10. Право оператора на проверку; порядок её проведения. 11. Ответственность и её ограничение (стыкуется с основным договором). 12. Порядок реагирования на обращения субъектов ПДн.

Соглашение о субпоручении (с оператором LLM-шлюза) — зеркальная структура, плюс: - Запрет логирования содержимого запросов и ответов; допустимый состав технических логов. - Максимальный срок хранения запроса на стороне шлюза. - Запрет дальнейшего субпоручения без письменного согласия. - Обязанность раскрыть фактическое место обработки и апстрим-провайдера. - Обязанность уведомить об инциденте в срок, позволяющий вам уложиться в 24 часа перед РКН (то есть ≤ 6 часов).

Порядок уничтожения ПДн 1. Основания уничтожения (достижение цели, отзыв согласия, требование субъекта, истечение срока, требование оператора). 2. Способы для каждого типа носителя: оперативная память (перезапись, завершение процесса), временные файлы, журналы, резервные копии (при их отсутствии — указать явно). 3. Сроки (по ст. 21 152-ФЗ). 4. Форма акта об уничтожении; форма выписки из журнала как подтверждения для заказчика. 5. Порядок подтверждения уничтожения субобработчиками.

9. Открытые вопросы — что нужно уточнить для точного вывода

Критические (без ответов выводы остаются условными):

1. **oui.interfonica.cloud** — что это фактически? Юрлицо-оператор, ИНН, где физически стоят серверы, есть ли апстрим и куда он ведёт. Тарификация «Selectel Gemma 4 31B» в `usage_log.py` указывает на Selectel — подтвердите или опровергните.
2. **Какая модель фактически обслуживает эндпоинт?** Gemma 4 (Apache-2.0) или Gemma 3/иная (Gemma ToU)? От этого зависит весь блок В.14. В коде дефолты противоречат друг другу.
3. **Логировались ли промпты на стороне шлюза?** Срок хранения, доступ, использование для обучения.
4. **Проходили ли через Vercel fra1 реальные документы заказчиков или только тестовые данные из test_samples/?** Это разница между «нарушение состоялось» и «нарушения не было». Есть ли логи, позволяющие это доказать?
5. **В какой период эксплуатировался fra1** (даты начала и окончания)? Нужно для оценки срока давности.
6. **Кто юридически является вами?** ИП, ООО, физическое лицо? От этого зависят размеры санкций (для юрлиц они на порядок выше) и способность заключать договоры поручения.
7. **Есть ли уже действующие клиенты и обрабатывались ли реальные ПДн?** Если да — обязанности возникли уже сейчас, а не с момента сделки с ИНК.

Важные:

8. **<https://anon.cpcore.ru>** (из `loadtest.py`) — чей это домен, что там развёрнуто, доступен ли публично, обрабатывались ли через него реальные документы?
9. **<https://jh.interfonica.cloud/user/ts-.../proxy/8000>** (из `app.py`) — JupyterHub используется как продовый путь или это артефакт разработки? Кто имеет доступ к этому JupyterHub?
10. **Планируются ли документы со специальными категориями ПДн** (медицинские, о судимости) и биометрией? От ответа зависит УЗ-2 против УЗ-3, а значит — необходимость сертифицированных СЗИ.
11. **Формат поставки ИНК:** SaaS, on-prem или гибридный? Это определяет, применяется ли лицензионный блок «distribution» и требования КИИ.

12. Известна ли категория значимости объектов КИИ ИНК, в контуре которых предполагается использование? Запросить у заказчика до коммерческого предложения.
13. Какие точно документы от Интерфоники уже получены? Аттестат, лицензия, договор поручения — или только устные заверения о «лицензии по 152-ФЗ»?
14. Заключён ли договор поручения обработки хотя бы с одним текущим клиентом?
15. Есть ли назначенный ответственный за организацию обработки ПДн и подано ли уведомление в РКН?

Уточняющие:

16. Планируется ли дообучение (fine-tuning) моделей? Если да — на каких данных и с какой лицензией? Это меняет лицензионную картину (появляются Model Derivatives).
17. Какова целевая выручка и структура собственности? Влияет на перспективы реестра российского ПО (критерий контроля $\geq 50\%$) и на расчёт оборотного штрафа.
18. Есть ли намерение выходить на госзаказчиков? Тогда реестр ПО и аттестация становятся обязательными.
19. Какие метрики полноты фактически получены на `eval_benchmark.py` и на каком наборе?
20. Модифицировались ли словари OpenCorpora (файлы `custom_terms.txt`, `glossary.py`)? Если да — ShareAlike применяется к результату.

10. Дисклеймер

Настоящий анализ подготовлен на основании открытых источников и содержимого репозитория по состоянию на 16 августа 2026 г. Он **не является юридическим заключением** и **не заменяет** ни заключение практикующего юриста, ни аудит информационной безопасности.

Отдельно обращаю внимание:

- Все суммы штрафов и часть реквизитов нормативных актов, помеченные [ПРОВЕРИТЬ], взяты из вторичных источников (правовых агрегаторов) и **подлежат обязательной сверке с первоисточниками** (`pravo.gov.ru`, `consultant.ru`, официальные публикации) до использования в переговорах, договорах или внутренних документах.
- Правоприменительная практика по редакции ст. 13.11 КоАП, действующей с 30.05.2025, и по ст. 272.1 УК только формируется; оценки вероятности и размеров санкций носят прогнозный характер.
- Позиции, помеченные [СПОРНО], отражают действительную неопределённость нормы; в каждом случае указано консервативное толкование, и именно его следует принимать при подготовке к работе с корпоративным заказчиком.
- Выводы построены на фактическом состоянии репозитория `privacy-filter-main/anonymizer`. Если продовая конфигурация отличается от кода в репозитории, выводы требуют пересмотра.

Перед подписанием договора с корпоративным заказчиком уровня ИНК обязательны: (1) правовая экспертиза договора и соглашения о поручении обработки практикующим юристом по персональным данным; (2) независимый аудит информационной безопасности с тестированием на проникновение. Стоимость обоих на порядок ниже цены одной ошибки в этих документах.

Источники

Нормативные акты и первоисточники:

- [Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных» \(ред. от 26.07.2026\)](#)
- [Ст. 12 152-ФЗ «Трансграничная передача персональных данных»](#)
- [Ст. 6 152-ФЗ «Условия обработки персональных данных»](#)
- [Федеральный закон от 26.07.2026 № 265-ФЗ \(изменения в ст. 12 152-ФЗ\)](#)
- [Федеральный закон от 08.08.2024 № 233-ФЗ \(обезличенные данные, ГИС Минцифры\)](#)
- [Федеральный закон от 26.07.2026 № 243-ФЗ «О поддержке развития технологий искусственного интеллекта» — обзор](#)
- [Приказ Роскомнадзора от 19.06.2025 № 140 «Об утверждении требований к обезличиванию персональных данных...» · обзор · текст в «Российской газете»](#)
- [Приказ Роскомнадзора от 05.09.2013 № 996 \(утратил силу с 01.09.2025\)](#)
- [Постановление Правительства РФ от 01.11.2012 № 1119 \(уровни защищённости ИСПДн\)](#)
- [Приказ ФСТЭК России от 18.02.2013 № 21 \(ред. от 14.05.2020\)](#)
- [Приказ ФСБ России от 10.07.2014 № 378 \(меры при использовании СКЗИ\)](#)
- [Постановление Правительства РФ от 08.02.2018 № 127 \(категорирование объектов КИИ, ред. от 07.11.2025\)](#)
- [Федеральный закон от 26.07.2017 № 187-ФЗ «О безопасности КИИ»](#)
- [Постановление Правительства РФ от 16.11.2015 № 1236 \(реестр российского ПО, ред. от 09.12.2025\)](#)
- [Федеральный закон от 29.07.2004 № 98-ФЗ «О коммерческой тайне»](#)
- [Ст. 272.1 УК РФ \(ред. от 26.07.2026\)](#)
- [Ст. 4.5 КоАП РФ \(давность привлечения к ответственности\)](#)
- [Ст. 13.11 КоАП РФ](#)
- [Персональные данные: новые штрафы с 30 мая 2025 года \(ФЗ от 30.11.2024 № 420-ФЗ\) — КонсультантПлюс](#)

Лицензии компонентов:

- [Gemma Terms of Use \(ред. 01.04.2026\)](#)
- [Gemma 4 license — Apache License 2.0](#)
- [Gemma Prohibited Use Policy](#)
- [knowledgator/gliner-relex-multi-v1.0 — License: apache-2.0](#)
- [py morphology3-dicts-ru \(PyPI\) — словари OpenCorpora](#)

Вспомогательные (вторичные) источники, использованные для сумм и реквизитов, помеченных [ПРОВЕРИТЬ]:

- [Штрафы за нарушение 152-ФЗ: полная таблица КоАП 13.11 \(2026\)](#)
- [Ответственность по ст. 13.11 КоАП 2026 — Ветров и партнёры](#)
- [Импортозамещение КИИ в 2026: сроки, требования и план перехода](#)
- [187-ФЗ о безопасности КИИ: новые требования 2025–2026](#)
- [Реестр отечественного ПО 2026: новые правила](#)
- [Соответствие 152-ФЗ — Selectel](#)
- [Кому можно поручить обработку персональных данных — b-152.ru](#)
- [Уведомление в Роскомнадзор об обработке персональных данных в 2026 году — Контур](#)